Scan Report

January 26, 2026

Summary

This document reports on the results of an automatic security scan. All dates are displayed using the timezone "Coordinated Universal Time", which is abbreviated "UTC". The task was " hgdfdghgdgd". The scan started at Mon Jan 26 01:47:47 2026 UTC and ended at Mon Jan 26 14:04:13 2026 UTC. The report first summarises the results found. Then, for each host, the report describes every issue found. Please consider the advice given in each description, in order to rectify the issue.

Contents

1 Result Overview **2**

2 Results per Host **2**

2.1 172.31.1.57 2

2.1.1 Critical 3000/tcp 2

2.1.2 Critical 22/tcp 3

2.1.3 High 22/tcp 5

2.1.4 Medium 3000/tcp 10

2.1.5 Medium 22/tcp 21

2.1.6 Low general/tcp 43

2.1.7 Low general/icmp 44

2.1.8 Low 22/tcp 45

2.1.9 Log general/tcp 49

2.1.10 Log 3000/tcp 53

2.1.11 Log 22/tcp 58

2.1.12 Log general/CPE-T 63

1 Result Overview

Host	Critical	High	Medium	Low	Log	False P.
172.31.1.57 gitea14.trabalho_vulnnet	2	3	18	5	17	0
Total: 1	2	3	18	5	17	0

Vendor security updates are not trusted.
Overrides are off. Even when a result has an override, this report uses the actual threat of the result.
Information on overrides is included in the report.
Notes are included in the report.
This report might not show details of all issues that were found.
Issues with the threat level "Debug" are not shown.

This report contains all 45 results selected by the filtering described above. Before filtering there were 5586 results.

2 Results per Host

2.1 172.31.1.57

Host scan start	Mon Jan 26 10:41:41 2026 UTC
Host scan end	Mon Jan 26 12:25:29 2026 UTC

Service (Port)	Threat Level
3000/tcp	Critical
22/tcp	Critical
22/tcp	High
3000/tcp	Medium
22/tcp	Medium
general/tcp	Low
general/icmp	Low
22/tcp	Low
general/tcp	Log
3000/tcp	Log
22/tcp	Log
general/CPE-T	Log

2.1.1 Critical 3000/tcp

Critical (CVSS: 9.9)
NVT: jQuery End of Life (EOL) Detection - Linux

Summary
The jQuery version on the remote host has reached the end of life (EOL) and should not be used anymore.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
The "jQuery" version on the remote host has reached the end of life.
CPE:                cpe:/a:jquery:jquery:1.11.3
Installed version: 1.11.3
Location/URL:       /vendor/plugins/jquery/jquery.min.js
EOL version:        1
EOL date:           unknown
Detection info (see OID: 1.3.6.1.4.1.25623.1.0.150658 for more info):
- Identified file: http://gitea14.trabalho_vulnnet:3000/vendor/plugins/jquery/jq
↪uery.min.js
- Referenced at:   http://gitea14.trabalho_vulnnet:3000/install/
```

Impact
An EOL version of jQuery is not receiving any security updates from the vendor. Unfixed security vulnerabilities might be leveraged by an attacker to compromise the security of this host.

Solution:
Solution type: VendorFix
Update jQuery on the remote host to a still supported version.

Vulnerability Detection Method
Checks if an EOL version is present on the target host.
Details: `jQuery End of Life (EOL) Detection - Linux`
OID:1.3.6.1.4.1.25623.1.0.117149
Version used: `2025-04-15T05:54:49Z`

References
`url: https://github.com/jquery/jquery.com/pull/163`

[return to 172.31.1.57]

2.1.2 Critical 22/tcp

Critical (CVSS: 9.8)
NVT: OpenBSD OpenSSH < 9.3p2 RCE Vulnerability

. . . continues on next page . . .

. . . continued from previous page . . .

Product detection result
`cpe:/a:openbsd:openssh:7.5`
`Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)`

Summary
OpenBSD OpenSSH is prone to a remote code execution (RCE) vulnerability in OpenSSH's forwarded ssh-agent.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     9.3p2
Installation
path / port:       22/tcp
```

Solution:
Solution type: VendorFix
Update to version 9.3p2 or later.

Affected Software/OS
OpenBSD OpenSSH prior to version 9.3p2.
The following conditions needs to be met:
- Exploitation requires the presence of specific libraries on the victim system.
- Remote exploitation requires that the agent was forwarded to an attacker-controlled system.

Vulnerability Insight
A condition where specific libraries loaded via ssh-agent(1)'s PKCS#11 support could be abused to achieve remote code execution via a forwarded agent socket.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenBSD OpenSSH < 9.3p2 RCE Vulnerability`
OID:1.3.6.1.4.1.25623.1.0.104869
Version used: `2023-10-13T05:06:10Z`

Product Detection Result
Product: `cpe:/a:openbsd:openssh:7.5`
Method: `OpenSSH Detection Consolidation`
OID: 1.3.6.1.4.1.25623.1.0.108577)

References
`cve: CVE-2023-38408`
`url: https://www.openssh.com/releasenotes.html#9.3p2`

. . . continues on next page . . .

. . . continued from previous page . . .

```
url: https://www.qualys.com/2023/07/19/cve-2023-38408/rce-openssh-forwarded-ssh-
↪agent.txt
cert-bund: WID-SEC-2024-3195
cert-bund: WID-SEC-2024-1248
cert-bund: WID-SEC-2024-1082
cert-bund: WID-SEC-2024-0064
cert-bund: WID-SEC-2023-2679
cert-bund: WID-SEC-2023-2625
cert-bund: WID-SEC-2023-2240
cert-bund: WID-SEC-2023-1843
cert-bund: WID-SEC-2023-1819
dfn-cert: DFN-CERT-2026-0097
dfn-cert: DFN-CERT-2025-2802
dfn-cert: DFN-CERT-2024-1260
dfn-cert: DFN-CERT-2024-0491
dfn-cert: DFN-CERT-2023-2792
dfn-cert: DFN-CERT-2023-2179
dfn-cert: DFN-CERT-2023-1961
dfn-cert: DFN-CERT-2023-1920
dfn-cert: DFN-CERT-2023-1845
dfn-cert: DFN-CERT-2023-1773
dfn-cert: DFN-CERT-2023-1665
```

[return to 172.31.1.57]

2.1.3 High 22/tcp

High (CVSS: 7.5)
NVT: Diffie-Hellman Ephemeral Key Exchange DoS Vulnerability (SSH, D(HE)ater)

Product detection result

```
cpe:/a:ietf:secure_shell_protocol
Detected by SSH Protocol Algorithms Supported (OID: 1.3.6.1.4.1.25623.1.0.105565
↪)
```

Summary

The remote SSH server is supporting Diffie-Hellman ephemeral (DHE) Key Exchange (KEX) algorithms and thus could be prone to a denial of service (DoS) vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
The remote SSH server supports the following DHE KEX algorithm(s):
diffie-hellman-group14-sha1
diffie-hellman-group14-sha256
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
diffie-hellman-group16-sha512
diffie-hellman-group18-sha512
diffie-hellman-group-exchange-sha256
```

Impact
This vulnerability allows remote attackers (from the client side) to send arbitrary numbers that are actually not public keys, and trigger expensive server-side DHE modular-exponentiation calculations, also known as a D(HE)ater attack.
There could be an increase in CPU usage in the affected component. For OpenSSH, users may observe issues such as a slowdown in SSH connections.

Solution:
Solution type: Mitigation
- DHE key exchange should be disabled if no other mitigation mechanism can be used and either elliptic-curve variant of Diffie-Hellman (ECDHE) or RSA key exchange is supported by the clients. The fact that RSA key exchange is not forward secret should be considered.
- Limit the maximum number of concurrent connections in e.g. the configuration of the remote server. For OpenSSH this limit can be configured via the 'MaxStartups' option, for other products please refer to the manual of the product in question on configuration possibilities.

Vulnerability Insight
- CVE-2002-20001: The Diffie-Hellman Key Agreement Protocol allows remote attackers (from the client side) to send arbitrary numbers that are actually not public keys, and trigger expensive server-side DHE modular-exponentiation calculations, aka a D(HE)ater attack. The client needs very little CPU resources and network bandwidth. The attack may be more disruptive in cases where a client can require a server to select its largest supported key size. The basic attack scenario is that the client must claim that it can only communicate with DHE, and the server must be configured to allow DHE.
- CVE-2022-40735: The Diffie-Hellman Key Agreement Protocol allows use of long exponents that arguably make certain calculations unnecessarily expensive, because the 1996 van Oorschot and Wiener paper found that '(appropriately) short exponents' can be used when there are adequate subgroup constraints, and these short exponents can lead to less expensive calculations than for long exponents. This issue is different from CVE-2002-20001 because it is based on an observation about exponent size, rather than an observation about numbers that are not public keys. The specific situations in which calculation expense would constitute a server-side vulnerability depend on the protocol (e.g., TLS, SSH, or IKE) and the DHE implementation details. In general, there might be an availability concern because of server-side resource consumption from DHE modular-exponentiation calculations. Finally, it is possible for an attacker to exploit this vulnerability and CVE-2002-20001 together.
- CVE-2024-41996: Validating the order of the public keys in the Diffie-Hellman Key Agreement Protocol, when an approved safe prime is used, allows remote attackers (from the client side) to trigger unnecessarily expensive server-side DHE modular-exponentiation calculations. The client may cause asymmetric resource consumption. The basic attack scenario is that the client must claim that it can only communicate with DHE, and the server must be configured to allow DHE and validate the order of the public key.

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Detection Method
Checks the supported KEX algorithms of the remote SSH server.
Details: `Diffie-Hellman Ephemeral Key Exchange DoS Vulnerability (SSH, D(HE)ater)`
OID:1.3.6.1.4.1.25623.1.0.117839
Version used: `2024-10-03T05:05:33Z`

Product Detection Result
Product: `cpe:/a:ietf:secure_shell_protocol`
Method: `SSH Protocol Algorithms Supported`
OID: 1.3.6.1.4.1.25623.1.0.105565)

References
```
cve: CVE-2002-20001
cve: CVE-2022-40735
cve: CVE-2024-41996
url: https://dheatattack.gitlab.io/
url: https://dheatattack.gitlab.io/details/
url: https://www.researchgate.net/profile/Anton-Stiglic-2/publication/2401745_Se
↪curity_Issues_in_the_Diffie-Hellman_Key_Agreement_Protocol
url: https://github.com/Balasys/dheater
url: https://github.com/c0r0n3r/dheater
cert-bund: WID-SEC-2024-3056
cert-bund: WID-SEC-2023-1886
cert-bund: WID-SEC-2023-1352
cert-bund: WID-SEC-2022-2251
cert-bund: WID-SEC-2022-2000
cert-bund: CB-K22/0224
cert-bund: CB-K21/1276
dfn-cert: DFN-CERT-2025-3324
dfn-cert: DFN-CERT-2024-2847
dfn-cert: DFN-CERT-2024-2578
dfn-cert: DFN-CERT-2024-1671
dfn-cert: DFN-CERT-2023-1697
dfn-cert: DFN-CERT-2023-1332
dfn-cert: DFN-CERT-2022-2147
dfn-cert: DFN-CERT-2022-0437
dfn-cert: DFN-CERT-2021-2622
```

High (CVSS: 7.4)
NVT: OpenBSD OpenSSH <= 8.6 Command Injection Vulnerability

Product detection result
`cpe:/a:openbsd:openssh:7.5`
`Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)`

. . . continues on next page . . .

. . . continued from previous page . . .

Summary
OpenBSD OpenSSH is prone to a command injection vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     None
Installation
path / port:       22/tcp
```

Impact
Successful exploitation would allow an attacker to execute arbitrary code on the target machine.

Solution:
Solution type: WillNotFix
No known solution was made available for at least one year since the disclosure of this vulnerability. Likely none will be provided anymore. General solution options are to upgrade to a newer release, disable respective features, remove the product or replace the product by another one.

Affected Software/OS
OpenBSD OpenSSH through version 8.6 (initially reported for 8.3p1).

Vulnerability Insight
scp of OpenSSH allows command injection in spc.c via backtick characters in the destination argument.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenBSD OpenSSH <= 8.6 Command Injection Vulnerability`
OID:1.3.6.1.4.1.25623.1.0.113736
Version used: `2025-07-29T05:44:59Z`

Product Detection Result
Product: `cpe:/a:openbsd:openssh:7.5`
Method: `OpenSSH Detection Consolidation`
OID: 1.3.6.1.4.1.25623.1.0.108577)

References

```
cve: CVE-2020-15778
url: https://github.com/cpandya2909/CVE-2020-15778/
cert-bund: WID-SEC-2024-1082
cert-bund: WID-SEC-2023-1599
cert-bund: WID-SEC-2022-2413
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
cert-bund: WID-SEC-2022-1308
cert-bund: CB-K21/1268
dfn-cert: DFN-CERT-2024-1260
dfn-cert: DFN-CERT-2020-1691
```

High (CVSS: 7.0)
NVT: OpenSSH 6.2 <= 8.7 Privilege Escalation Vulnerability

Product detection result

```
cpe:/a:openbsd:openssh:7.5
Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)
```

Summary

OpenSSH is prone to a privilege scalation vulnerability in certain configurations.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     8.8
Installation
path / port:       22/tcp
```

Solution:

Solution type: VendorFix

Update to version 8.8 or later.

Affected Software/OS

OpenSSH versions 6.2 through 8.7.

Vulnerability Insight

sshd failed to correctly initialise supplemental groups when executing an AuthorizedKeysCommand or AuthorizedPrincipalsCommand, where a AuthorizedKeysCommandUser or AuthorizedPrincipalsCommandUser directive has been set to run the command as a different user. Instead these commands would inherit the groups that sshd was started with.

Depending on system configuration, inherited groups may allow AuthorizedKeysCommand/AuthorizedPrincipalsCommand helper programs to gain unintended privilege.

Neither AuthorizedKeysCommand nor AuthorizedPrincipalsCommand are enabled by default in sshd_config.

Vulnerability Detection Method

Checks if a vulnerable version is present on the target host.

Details: `OpenSSH 6.2 <= 8.7 Privilege Escalation Vulnerability`

OID:1.3.6.1.4.1.25623.1.0.117696

. . . continues on next page . . .

. . . continued from previous page . . .

Version used: 2021-10-11T08:01:31Z

Product Detection Result
Product: cpe:/a:openbsd:openssh:7.5
Method: OpenSSH Detection Consolidation
OID: 1.3.6.1.4.1.25623.1.0.108577)

References
cve: CVE-2021-41617
url: https://www.openssh.com/txt/release-8.8
cert-bund: WID-SEC-2024-1082
cert-bund: WID-SEC-2023-1969
cert-bund: WID-SEC-2023-0426
cert-bund: WID-SEC-2022-1308
cert-bund: WID-SEC-2022-0676
cert-bund: WID-SEC-2022-0534
cert-bund: CB-K22/0310
cert-bund: CB-K22/0011
cert-bund: CB-K21/1268
cert-bund: CB-K21/1017
dfn-cert: DFN-CERT-2024-1260
dfn-cert: DFN-CERT-2024-0022
dfn-cert: DFN-CERT-2023-3218
dfn-cert: DFN-CERT-2023-3210
dfn-cert: DFN-CERT-2022-1571
dfn-cert: DFN-CERT-2022-0579
dfn-cert: DFN-CERT-2021-2586
dfn-cert: DFN-CERT-2021-2017
dfn-cert: DFN-CERT-2021-2015

[return to 172.31.1.57]

2.1.4 Medium 3000/tcp

Medium (CVSS: 6.1)
NVT: jQuery < 3.0.0 XSS Vulnerability

Summary
jQuery is prone to a cross-site scripting (XSS) vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
Installed version: 1.11.3
Fixed version: 3.0.0

. . . continues on next page . . .

. . . continued from previous page . . .

```
Installation
path / port:       /vendor/plugins/jquery/jquery.min.js
Detection info (see OID: 1.3.6.1.4.1.25623.1.0.150658 for more info):
- Identified file: http://gitea14.trabalho_vulnnet:3000/vendor/plugins/jquery/jq
↪uery.min.js
- Referenced at:   http://gitea14.trabalho_vulnnet:3000/install/
```

Solution:
Solution type: VendorFix
Update to version 3.0.0 or later.

Affected Software/OS
jQuery prior to version 3.0.0.

Vulnerability Insight
When a cross-domain Ajax request is performed without the dataType option, causing text/javascript responses to be executed.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `jQuery < 3.0.0 XSS Vulnerability`
OID:1.3.6.1.4.1.25623.1.0.141635
Version used: `2023-07-14T05:06:08Z`

References

```
cve: CVE-2015-9251
url: https://github.com/jquery/jquery/issues/2432
cert-bund: WID-SEC-2025-1660
cert-bund: WID-SEC-2025-1212
cert-bund: WID-SEC-2024-1872
cert-bund: WID-SEC-2024-1682
cert-bund: WID-SEC-2023-0239
cert-bund: WID-SEC-2022-0673
cert-bund: CB-K22/0045
cert-bund: CB-K20/1030
cert-bund: CB-K20/0309
cert-bund: CB-K20/0041
cert-bund: CB-K19/0911
cert-bund: CB-K19/0909
cert-bund: CB-K19/0615
cert-bund: CB-K19/0321
cert-bund: CB-K19/0313
cert-bund: CB-K19/0054
cert-bund: CB-K19/0052
cert-bund: CB-K19/0049
cert-bund: CB-K19/0048
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
cert-bund: CB-K19/0046
cert-bund: CB-K18/1006
dfn-cert: DFN-CERT-2023-1197
dfn-cert: DFN-CERT-2023-0245
dfn-cert: DFN-CERT-2020-2423
dfn-cert: DFN-CERT-2020-2130
dfn-cert: DFN-CERT-2020-0630
dfn-cert: DFN-CERT-2020-0590
dfn-cert: DFN-CERT-2020-0318
dfn-cert: DFN-CERT-2019-2158
dfn-cert: DFN-CERT-2019-1455
dfn-cert: DFN-CERT-2019-0777
dfn-cert: DFN-CERT-2019-0772
dfn-cert: DFN-CERT-2019-0119
dfn-cert: DFN-CERT-2019-0111
dfn-cert: DFN-CERT-2018-2103
dfn-cert: DFN-CERT-2018-1163
```

Medium (CVSS: 6.1)
NVT: jQuery 1.0.3 < 3.5.0 XSS Vulnerability

Summary
jQuery is prone to a cross-site scripting (XSS) vulnerability when appending HTML containing option elements.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 1.11.3
Fixed version:     3.5.0
Installation
path / port:       /vendor/plugins/jquery/jquery.min.js
Detection info (see OID: 1.3.6.1.4.1.25623.1.0.150658 for more info):
- Identified file: http://gitea14.trabalho_vulnnet:3000/vendor/plugins/jquery/jq
↪uery.min.js
- Referenced at:   http://gitea14.trabalho_vulnnet:3000/install/
```

Solution:
Solution type: VendorFix
Update to version 3.5.0 or later.

Affected Software/OS
jQuery versions starting from 1.0.3 and prior to version 3.5.0.

Vulnerability Insight

. . . continues on next page . . .

. . . continued from previous page . . .

Passing HTML containing <option> elements from untrusted sources - even after sanitizing them - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `jQuery 1.0.3 < 3.5.0 XSS Vulnerability`
OID:1.3.6.1.4.1.25623.1.0.143813
Version used: `2025-01-31T15:39:24Z`

References
`cve: CVE-2020-11023`
`cisa: Known Exploited Vulnerability (KEV) catalog`
`url: https://www.cisa.gov/known-exploited-vulnerabilities-catalog`
`url: https://github.com/jquery/jquery/security/advisories/GHSA-jpcq-cgw6-v4j6`
`url: https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/`
`url: https://masatokinugawa.l0.cm/2020/05/jquery3.5.0-xss.html`
`url: https://security.snyk.io/vuln/SNYK-JS-JQUERY-565129`
`cert-bund: WID-SEC-2025-1459`
`cert-bund: WID-SEC-2024-3191`
`cert-bund: WID-SEC-2024-1872`
`cert-bund: WID-SEC-2023-0239`
`cert-bund: WID-SEC-2023-0063`
`cert-bund: WID-SEC-2022-1347`
`cert-bund: WID-SEC-2022-1189`
`cert-bund: WID-SEC-2022-0757`
`cert-bund: WID-SEC-2022-0732`
`cert-bund: CB-K21/1085`
`cert-bund: CB-K21/1067`
`cert-bund: CB-K21/0418`
`cert-bund: CB-K20/1049`
`cert-bund: CB-K20/1027`
`cert-bund: CB-K20/1025`
`cert-bund: CB-K20/1024`
`cert-bund: CB-K20/1021`
`cert-bund: CB-K20/1008`
`cert-bund: CB-K20/0870`
`cert-bund: CB-K20/0800`
`cert-bund: CB-K20/0705`
`cert-bund: CB-K20/0521`
`dfn-cert: DFN-CERT-2025-2802`
`dfn-cert: DFN-CERT-2025-1803`
`dfn-cert: DFN-CERT-2025-0559`
`dfn-cert: DFN-CERT-2025-0497`
`dfn-cert: DFN-CERT-2025-0373`
`dfn-cert: DFN-CERT-2025-0348`
`dfn-cert: DFN-CERT-2024-2743`

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2023-2027
dfn-cert: DFN-CERT-2023-1197
dfn-cert: DFN-CERT-2023-0481
dfn-cert: DFN-CERT-2023-0245
dfn-cert: DFN-CERT-2022-1988
dfn-cert: DFN-CERT-2022-1610
dfn-cert: DFN-CERT-2022-0119
dfn-cert: DFN-CERT-2022-0074
dfn-cert: DFN-CERT-2021-2348
dfn-cert: DFN-CERT-2021-1687
dfn-cert: DFN-CERT-2021-1111
dfn-cert: DFN-CERT-2021-0820
dfn-cert: DFN-CERT-2021-0633
dfn-cert: DFN-CERT-2021-0563
dfn-cert: DFN-CERT-2021-0545
dfn-cert: DFN-CERT-2020-2776
dfn-cert: DFN-CERT-2020-2423
dfn-cert: DFN-CERT-2020-2335
dfn-cert: DFN-CERT-2020-2287
dfn-cert: DFN-CERT-2020-2227
dfn-cert: DFN-CERT-2020-2209
dfn-cert: DFN-CERT-2020-2074
dfn-cert: DFN-CERT-2020-1743
dfn-cert: DFN-CERT-2020-1712
dfn-cert: DFN-CERT-2020-1509
dfn-cert: DFN-CERT-2020-1506
dfn-cert: DFN-CERT-2020-1433
dfn-cert: DFN-CERT-2020-1163
dfn-cert: DFN-CERT-2020-1099
```

Medium (CVSS: 6.1)
NVT: jQuery 1.2 < 3.5.0 XSS Vulnerability

Summary
jQuery is prone to a cross-site scripting (XSS) vulnerability in jQuery.htmlPrefilter and related methods.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 1.11.3
Fixed version:     3.5.0
Installation
path / port:       /vendor/plugins/jquery/jquery.min.js
Detection info (see OID: 1.3.6.1.4.1.25623.1.0.150658 for more info):
- Identified file: http://gitea14.trabalho_vulnnet:3000/vendor/plugins/jquery/jq
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
↪uery.min.js
- Referenced at:   http://gitea14.trabalho_vulnnet:3000/install/
```

Solution:
Solution type: VendorFix
Update to version 3.5.0 or later.

Affected Software/OS
jQuery versions starting from 1.2 and prior to version 3.5.0.

Vulnerability Insight
Passing HTML from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `jQuery 1.2 < 3.5.0 XSS Vulnerability`
OID:1.3.6.1.4.1.25623.1.0.143812
Version used: `2023-07-14T05:06:08Z`

References

```
cve: CVE-2020-11022
url: https://github.com/jquery/jquery/security/advisories/GHSA-gxr4-xjj5-5px2
url: https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/
url: https://masatokinugawa.l0.cm/2020/05/jquery3.5.0-xss.html
url: https://security.snyk.io/vuln/SNYK-JS-JQUERY-567880
cert-bund: WID-SEC-2025-1087
cert-bund: WID-SEC-2024-3217
cert-bund: WID-SEC-2024-1872
cert-bund: WID-SEC-2023-0239
cert-bund: WID-SEC-2023-0063
cert-bund: WID-SEC-2022-1767
cert-bund: WID-SEC-2022-1347
cert-bund: WID-SEC-2022-0740
cert-bund: WID-SEC-2022-0732
cert-bund: WID-SEC-2022-0624
cert-bund: CB-K22/0463
cert-bund: CB-K21/1085
cert-bund: CB-K21/0071
cert-bund: CB-K21/0070
cert-bund: CB-K21/0069
cert-bund: CB-K21/0067
cert-bund: CB-K21/0061
cert-bund: CB-K21/0059
cert-bund: CB-K20/1049
cert-bund: CB-K20/1030
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
cert-bund: CB-K20/1027
cert-bund: CB-K20/1025
cert-bund: CB-K20/1023
cert-bund: CB-K20/1008
cert-bund: CB-K20/0870
cert-bund: CB-K20/0800
cert-bund: CB-K20/0705
cert-bund: CB-K20/0521
dfn-cert: DFN-CERT-2025-1803
dfn-cert: DFN-CERT-2025-0559
dfn-cert: DFN-CERT-2025-0041
dfn-cert: DFN-CERT-2023-2027
dfn-cert: DFN-CERT-2023-1197
dfn-cert: DFN-CERT-2023-0481
dfn-cert: DFN-CERT-2023-0245
dfn-cert: DFN-CERT-2022-1988
dfn-cert: DFN-CERT-2022-1670
dfn-cert: DFN-CERT-2022-0869
dfn-cert: DFN-CERT-2022-0074
dfn-cert: DFN-CERT-2021-2190
dfn-cert: DFN-CERT-2021-1111
dfn-cert: DFN-CERT-2021-0828
dfn-cert: DFN-CERT-2021-0826
dfn-cert: DFN-CERT-2021-0819
dfn-cert: DFN-CERT-2021-0633
dfn-cert: DFN-CERT-2021-0545
dfn-cert: DFN-CERT-2021-0140
dfn-cert: DFN-CERT-2021-0138
dfn-cert: DFN-CERT-2021-0135
dfn-cert: DFN-CERT-2021-0132
dfn-cert: DFN-CERT-2020-2423
dfn-cert: DFN-CERT-2020-2335
dfn-cert: DFN-CERT-2020-2305
dfn-cert: DFN-CERT-2020-2286
dfn-cert: DFN-CERT-2020-2227
dfn-cert: DFN-CERT-2020-2209
dfn-cert: DFN-CERT-2020-2130
dfn-cert: DFN-CERT-2020-2074
dfn-cert: DFN-CERT-2020-2015
dfn-cert: DFN-CERT-2020-2001
dfn-cert: DFN-CERT-2020-1838
dfn-cert: DFN-CERT-2020-1812
dfn-cert: DFN-CERT-2020-1712
dfn-cert: DFN-CERT-2020-1509
dfn-cert: DFN-CERT-2020-1506
dfn-cert: DFN-CERT-2020-1433
dfn-cert: DFN-CERT-2020-1163
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2020-1161
dfn-cert: DFN-CERT-2020-1138
dfn-cert: DFN-CERT-2020-1099
```

Medium (CVSS: 6.1)
NVT: jQuery < 3.4.0 Object Extensions Vulnerability

Summary
jQuery is prone to multiple vulnerabilities regarding property injection in Object.prototype.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 1.11.3
Fixed version:     3.4.0
Installation
path / port:       /vendor/plugins/jquery/jquery.min.js
Detection info (see OID: 1.3.6.1.4.1.25623.1.0.150658 for more info):
- Identified file: http://gitea14.trabalho_vulnnet:3000/vendor/plugins/jquery/jq
↪uery.min.js
- Referenced at:   http://gitea14.trabalho_vulnnet:3000/install/
```

Solution:
Solution type: VendorFix
Update to version 3.4.0 or later. Patch diffs are available for older versions.

Affected Software/OS
jQuery prior to version 3.4.0.

Vulnerability Insight
The following flaws exist:
- CVE-2019-5428: A prototype pollution vulnerability exists that allows an attacker to inject properties on Object.prototype.
- CVE-2019-11358: jQuery mishandles jQuery.extend(true, }}, ...) because of Object.prototype pollution. If an unsanitized source object contained an enumerable __proto__ property, it could extend the native Object.prototype.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `jQuery < 3.4.0 Object Extensions Vulnerability`
OID:1.3.6.1.4.1.25623.1.0.142314
Version used: `2023-07-14T05:06:08Z`

References

```
cve: CVE-2019-5428
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
cve: CVE-2019-11358
url: https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/
url: https://github.com/DanielRuf/snyk-js-jquery-174006?files=1
cert-bund: WID-SEC-2024-1872
cert-bund: WID-SEC-2023-1737
cert-bund: WID-SEC-2023-0239
cert-bund: WID-SEC-2022-1948
cert-bund: WID-SEC-2022-1947
cert-bund: WID-SEC-2022-0732
cert-bund: WID-SEC-2022-0673
cert-bund: CB-K22/0045
cert-bund: CB-K21/1083
cert-bund: CB-K20/1049
cert-bund: CB-K20/1030
cert-bund: CB-K20/0800
cert-bund: CB-K20/0710
cert-bund: CB-K20/0324
cert-bund: CB-K20/0314
cert-bund: CB-K20/0309
cert-bund: CB-K20/0106
cert-bund: CB-K20/0041
cert-bund: CB-K20/0037
cert-bund: CB-K20/0034
cert-bund: CB-K19/0921
cert-bund: CB-K19/0920
cert-bund: CB-K19/0916
cert-bund: CB-K19/0911
cert-bund: CB-K19/0909
cert-bund: CB-K19/0619
cert-bund: CB-K19/0504
cert-bund: CB-K19/0329
dfn-cert: DFN-CERT-2025-1803
dfn-cert: DFN-CERT-2024-1997
dfn-cert: DFN-CERT-2023-2027
dfn-cert: DFN-CERT-2023-1197
dfn-cert: DFN-CERT-2023-0481
dfn-cert: DFN-CERT-2023-0245
dfn-cert: DFN-CERT-2022-2467
dfn-cert: DFN-CERT-2021-1536
dfn-cert: DFN-CERT-2021-1503
dfn-cert: DFN-CERT-2021-0826
dfn-cert: DFN-CERT-2020-2423
dfn-cert: DFN-CERT-2020-2335
dfn-cert: DFN-CERT-2020-2286
dfn-cert: DFN-CERT-2020-2130
dfn-cert: DFN-CERT-2020-1812
dfn-cert: DFN-CERT-2020-1574
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2020-1537
dfn-cert: DFN-CERT-2020-1506
dfn-cert: DFN-CERT-2020-0772
dfn-cert: DFN-CERT-2020-0769
dfn-cert: DFN-CERT-2020-0721
dfn-cert: DFN-CERT-2020-0276
dfn-cert: DFN-CERT-2020-0102
dfn-cert: DFN-CERT-2020-0100
dfn-cert: DFN-CERT-2019-2169
dfn-cert: DFN-CERT-2019-2158
dfn-cert: DFN-CERT-2019-2156
dfn-cert: DFN-CERT-2019-2126
dfn-cert: DFN-CERT-2019-1861
dfn-cert: DFN-CERT-2019-1663
dfn-cert: DFN-CERT-2019-1460
dfn-cert: DFN-CERT-2019-1182
dfn-cert: DFN-CERT-2019-1153
dfn-cert: DFN-CERT-2019-1118
dfn-cert: DFN-CERT-2019-1033
dfn-cert: DFN-CERT-2019-0914
dfn-cert: DFN-CERT-2019-0899
dfn-cert: DFN-CERT-2019-0805
```

Medium (CVSS: 5.0)
NVT: Missing 'HttpOnly' Cookie Attribute (HTTP)

Summary
The remote HTTP web server / application is missing to set the 'HttpOnly' cookie attribute for one or more sent HTTP cookie.

Quality of Detection (QoD): 70%

Vulnerability Detection Result

```
The cookie(s):
Set-Cookie: lang=en-US; Path=/; Max-Age=2147483647
is/are missing the "HttpOnly" cookie attribute.
```

Solution:
Solution type: Mitigation
- Set the 'HttpOnly' cookie attribute for any session cookie
- Evaluate / do an own assessment of the security impact on the web server / application and create an override for this result if there is none (this can't be checked automatically by this VT)

Affected Software/OS
Any web application with session handling in cookies.

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Insight
The flaw exists if a session cookie is not using the 'HttpOnly' cookie attribute.
This allows a cookie to be accessed by JavaScript which could lead to session hijacking attacks.

Vulnerability Detection Method
Checks all cookies sent by the remote HTTP web server / application for a missing 'HttpOnly' cookie attribute.
Details: `Missing 'HttpOnly' Cookie Attribute (HTTP)`
OID:1.3.6.1.4.1.25623.1.0.105925
Version used: `2024-01-12T16:12:12Z`

References
`url: https://www.rfc-editor.org/rfc/rfc6265#section-5.2.6`
`url: https://owasp.org/www-community/HttpOnly`
`url: https://wiki.owasp.org/index.php/Testing_for_cookies_attributes_(OTG-SESS-0`
`↪02)`

Medium (CVSS: 4.8)
NVT: Cleartext Transmission of Sensitive Information via HTTP

Summary
The host / application transmits sensitive information (username, passwords) in cleartext via HTTP.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
`The following input fields were identified (URL:input name):`
`http://gitea14.trabalho_vulnnet:3000/install:db_passwd`

Impact
An attacker could use this situation to compromise or eavesdrop on the HTTP communication between the client and the server using a man-in-the-middle attack to get access to sensitive data like usernames or passwords.

Solution:
Solution type: Workaround
Enforce the transmission of sensitive data via an encrypted SSL/TLS connection. Additionally make sure the host / application is redirecting all users to the secured SSL/TLS connection before allowing to input sensitive data into the mentioned functions.

Affected Software/OS
Hosts / applications which doesn't enforce the transmission of sensitive data via an encrypted SSL/TLS connection.

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Detection Method
Evaluate previous collected information and check if the host / application is not enforcing the transmission of sensitive data via an encrypted SSL/TLS connection.
The script is currently checking the following:
- HTTP Basic Authentication (Basic Auth)
- HTTP Forms (e.g. Login) with input field of type 'password'
Details: `Cleartext Transmission of Sensitive Information via HTTP`
OID:1.3.6.1.4.1.25623.1.0.108440
Version used: `2023-09-07T05:05:21Z`

References
`url: https://www.owasp.org/index.php/Top_10_2013-A2-Broken_Authentication_and_Se`
`↪ssion_Management`
`url: https://www.owasp.org/index.php/Top_10_2013-A6-Sensitive_Data_Exposure`
`url: https://cwe.mitre.org/data/definitions/319.html`

[return to 172.31.1.57]

2.1.5 Medium 22/tcp

Medium (CVSS: 6.8)
NVT: OpenBSD OpenSSH 6.8p1 - 9.9p1 MitM Vulnerability

Product detection result
`cpe:/a:openbsd:openssh:7.5`
`Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)`

Summary
OpenBSD OpenSSH is prone to a man-in-the-middle (MitM) vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
```
Installed version: 7.5
Fixed version:     9.9p2
Installation
path / port:       22/tcp
```

Solution:
Solution type: VendorFix
Update to version 9.9p2 or later.

Affected Software/OS

. . . continues on next page . . .

. . . continued from previous page . . .

OpenBSD OpenSSH versions 6.8p1 through 9.9p1.

Vulnerability Insight
ssh(1) in OpenSSH contained a logic error that allowed an on-path attacker (a.k.a MITM) to impersonate any server when the VerifyHostKeyDNS option is enabled. This option is off by default.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenBSD OpenSSH 6.8p1 - 9.9p1 MitM Vulnerability`
OID:1.3.6.1.4.1.25623.1.0.114946
Version used: `2025-02-20T08:47:14Z`

Product Detection Result
Product: `cpe:/a:openbsd:openssh:7.5`
Method: `OpenSSH Detection Consolidation`
OID: 1.3.6.1.4.1.25623.1.0.108577)

References
```
cve: CVE-2025-26465
url: https://www.openssh.com/txt/release-9.9p2
url: https://www.openssh.com/security.html
url: https://www.qualys.com/2025/02/18/openssh-mitm-dos.txt
url: https://blog.qualys.com/vulnerabilities-threat-research/2025/02/18/qualys-t
↪ru-discovers-two-vulnerabilities-in-openssh-cve-2025-26465-cve-2025-26466
url: https://www.openwall.com/lists/oss-security/2025/02/18/1
url: https://www.openwall.com/lists/oss-security/2025/02/18/4
cert-bund: WID-SEC-2025-1439
cert-bund: WID-SEC-2025-1007
cert-bund: WID-SEC-2025-0394
dfn-cert: DFN-CERT-2026-0097
dfn-cert: DFN-CERT-2025-1201
dfn-cert: DFN-CERT-2025-1200
dfn-cert: DFN-CERT-2025-0993
dfn-cert: DFN-CERT-2025-0819
dfn-cert: DFN-CERT-2025-0470
dfn-cert: DFN-CERT-2025-0428
```

Medium (CVSS: 6.8)
NVT: OpenBSD OpenSSH <= 7.9 Multiple Vulnerabilities

Product detection result
`cpe:/a:openbsd:openssh:7.5`
`Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)`

. . . continues on next page . . .

. . . continued from previous page . . .

Summary
OpenBSD OpenSSH is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     8.0
Installation
path / port:       22/tcp
```

Solution:
Solution type: VendorFix
Update to version 8.0 or later.

Affected Software/OS
OpenBSD OpenSSH versions 7.9 and prior.

Vulnerability Insight
The following flaws exist:
- CVE-2018-20685: bypass of intended access restrictions in the scp client
- CVE-2019-6109, CVE-2019-6110: manipulation of the output in the scp client by a malicious server
- CVE-2019-6111: overwrite of arbitrary files in the scp client by a malicious server

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenBSD OpenSSH <= 7.9 Multiple Vulnerabilities`
OID:1.3.6.1.4.1.25623.1.0.117786
Version used: `2023-10-20T16:09:12Z`

Product Detection Result
Product: `cpe:/a:openbsd:openssh:7.5`
Method: `OpenSSH Detection Consolidation`
OID: 1.3.6.1.4.1.25623.1.0.108577)

References

```
cve: CVE-2018-20685
cve: CVE-2019-6109
cve: CVE-2019-6110
cve: CVE-2019-6111
url: https://sintonen.fi/advisories/scp-client-multiple-vulnerabilities.txt
url: http://www.openwall.com/lists/oss-security/2019/04/18/1
cert-bund: WID-SEC-2024-1082
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
cert-bund: WID-SEC-2024-0872
cert-bund: WID-SEC-2023-1995
cert-bund: WID-SEC-2023-0561
cert-bund: CB-K19/0627
cert-bund: CB-K19/0312
cert-bund: CB-K19/0058
cert-bund: CB-K19/0037
dfn-cert: DFN-CERT-2024-1260
dfn-cert: DFN-CERT-2019-2157
dfn-cert: DFN-CERT-2019-1470
dfn-cert: DFN-CERT-2019-0970
dfn-cert: DFN-CERT-2019-0776
dfn-cert: DFN-CERT-2019-0563
dfn-cert: DFN-CERT-2019-0415
dfn-cert: DFN-CERT-2019-0357
dfn-cert: DFN-CERT-2019-0275
dfn-cert: DFN-CERT-2019-0136
dfn-cert: DFN-CERT-2019-0094
```

Medium (CVSS: 6.5)
NVT: OpenBSD OpenSSH < 9.6 Multiple Vulnerabilities (Terrapin Attack)

Product detection result

```
cpe:/a:openbsd:openssh:7.5
Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)
```

Summary

OpenBSD OpenSSH is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     9.6
Installation
path / port:       22/tcp
```

Solution:

Solution type: VendorFix

Update to version 9.6 or later.

Note: Client and Server implementations need to run a fixed version to mitigate the Terrapin flaw.

Affected Software/OS

. . . continues on next page . . .

. . . continued from previous page . . .

OpenBSD OpenSSH prior to version 9.6.

Vulnerability Insight
The following vulnerabilities exist:
- CVE-2023-48795: The SSH transport protocol with certain OpenSSH extensions allows remote attackers to bypass integrity checks such that some packets are omitted (from the extension negotiation message), and a client and server may consequently end up with a connection for which some security features have been downgraded or disabled, aka a 'Terrapin attack'.
- CVE-2023-51384: In ssh-agent certain destination constraints can be incompletely applied. When destination constraints are specified during addition of PKCS#11-hosted private keys, these constraints are only applied to the first key, even if a PKCS#11 token returns multiple keys.
- CVE-2023-51385: OS command injection might occur if a user name or host name has shell metacharacters, and this name is referenced by an expansion token in certain situations. For example, an untrusted Git repository can have a submodule with shell metacharacters in a user name or host name.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenBSD OpenSSH < 9.6 Multiple Vulnerabilities (Terrapin Attack)`
OID:1.3.6.1.4.1.25623.1.0.118572
Version used: `2025-10-08T05:38:55Z`

Product Detection Result
Product: `cpe:/a:openbsd:openssh:7.5`
Method: `OpenSSH Detection Consolidation`
OID: 1.3.6.1.4.1.25623.1.0.108577)

References
```
cve: CVE-2023-48795
cve: CVE-2023-51384
cve: CVE-2023-51385
url: https://www.openssh.com/txt/release-9.6
url: https://terrapin-attack.com
url: https://vin01.github.io/piptagole/ssh/security/openssh/libssh/remote-code-e
↪xecution/2023/12/20/openssh-proxycommand-libssh-rce.html
url: https://github.com/vin01/poc-proxycommand-vulnerable
cert-bund: WID-SEC-2025-0810
cert-bund: WID-SEC-2025-0168
cert-bund: WID-SEC-2025-0144
cert-bund: WID-SEC-2025-0139
cert-bund: WID-SEC-2024-3377
cert-bund: WID-SEC-2024-3320
cert-bund: WID-SEC-2024-3198
cert-bund: WID-SEC-2024-3195
cert-bund: WID-SEC-2024-3140
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
cert-bund: WID-SEC-2024-1913
cert-bund: WID-SEC-2024-1781
cert-bund: WID-SEC-2024-1701
cert-bund: WID-SEC-2024-1656
cert-bund: WID-SEC-2024-1655
cert-bund: WID-SEC-2024-1643
cert-bund: WID-SEC-2024-1642
cert-bund: WID-SEC-2024-1639
cert-bund: WID-SEC-2024-1637
cert-bund: WID-SEC-2024-1630
cert-bund: WID-SEC-2024-1474
cert-bund: WID-SEC-2024-1248
cert-bund: WID-SEC-2024-1228
cert-bund: WID-SEC-2024-1186
cert-bund: WID-SEC-2024-1082
cert-bund: WID-SEC-2024-0899
cert-bund: WID-SEC-2024-0892
cert-bund: WID-SEC-2024-0889
cert-bund: WID-SEC-2024-0885
cert-bund: WID-SEC-2024-0874
cert-bund: WID-SEC-2024-0869
cert-bund: WID-SEC-2024-0578
cert-bund: WID-SEC-2024-0564
cert-bund: WID-SEC-2024-0523
cert-bund: WID-SEC-2023-3182
cert-bund: WID-SEC-2023-3174
dfn-cert: DFN-CERT-2026-0097
dfn-cert: DFN-CERT-2025-3629
dfn-cert: DFN-CERT-2025-3272
dfn-cert: DFN-CERT-2025-2058
dfn-cert: DFN-CERT-2025-2037
dfn-cert: DFN-CERT-2025-1447
dfn-cert: DFN-CERT-2025-1177
dfn-cert: DFN-CERT-2025-1025
dfn-cert: DFN-CERT-2025-0660
dfn-cert: DFN-CERT-2025-0502
dfn-cert: DFN-CERT-2025-0294
dfn-cert: DFN-CERT-2025-0173
dfn-cert: DFN-CERT-2025-0165
dfn-cert: DFN-CERT-2025-0024
dfn-cert: DFN-CERT-2024-3171
dfn-cert: DFN-CERT-2024-2818
dfn-cert: DFN-CERT-2024-2759
dfn-cert: DFN-CERT-2024-2741
dfn-cert: DFN-CERT-2024-2682
dfn-cert: DFN-CERT-2024-2602
dfn-cert: DFN-CERT-2024-2573
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2024-2392
dfn-cert: DFN-CERT-2024-2210
dfn-cert: DFN-CERT-2024-2209
dfn-cert: DFN-CERT-2024-2194
dfn-cert: DFN-CERT-2024-2169
dfn-cert: DFN-CERT-2024-2048
dfn-cert: DFN-CERT-2024-2030
dfn-cert: DFN-CERT-2024-2028
dfn-cert: DFN-CERT-2024-1930
dfn-cert: DFN-CERT-2024-1895
dfn-cert: DFN-CERT-2024-1869
dfn-cert: DFN-CERT-2024-1868
dfn-cert: DFN-CERT-2024-1865
dfn-cert: DFN-CERT-2024-1862
dfn-cert: DFN-CERT-2024-1854
dfn-cert: DFN-CERT-2024-1846
dfn-cert: DFN-CERT-2024-1817
dfn-cert: DFN-CERT-2024-1794
dfn-cert: DFN-CERT-2024-1715
dfn-cert: DFN-CERT-2024-1698
dfn-cert: DFN-CERT-2024-1688
dfn-cert: DFN-CERT-2024-1655
dfn-cert: DFN-CERT-2024-1600
dfn-cert: DFN-CERT-2024-1443
dfn-cert: DFN-CERT-2024-1442
dfn-cert: DFN-CERT-2024-1413
dfn-cert: DFN-CERT-2024-1382
dfn-cert: DFN-CERT-2024-1380
dfn-cert: DFN-CERT-2024-1373
dfn-cert: DFN-CERT-2024-1260
dfn-cert: DFN-CERT-2024-1259
dfn-cert: DFN-CERT-2024-1108
dfn-cert: DFN-CERT-2024-1061
dfn-cert: DFN-CERT-2024-1029
dfn-cert: DFN-CERT-2024-1003
dfn-cert: DFN-CERT-2024-1000
dfn-cert: DFN-CERT-2024-0896
dfn-cert: DFN-CERT-2024-0779
dfn-cert: DFN-CERT-2024-0762
dfn-cert: DFN-CERT-2024-0744
dfn-cert: DFN-CERT-2024-0698
dfn-cert: DFN-CERT-2024-0633
dfn-cert: DFN-CERT-2024-0619
dfn-cert: DFN-CERT-2024-0618
dfn-cert: DFN-CERT-2024-0616
dfn-cert: DFN-CERT-2024-0597
dfn-cert: DFN-CERT-2024-0545
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2024-0526
dfn-cert: DFN-CERT-2024-0491
dfn-cert: DFN-CERT-2024-0480
dfn-cert: DFN-CERT-2024-0451
dfn-cert: DFN-CERT-2024-0440
dfn-cert: DFN-CERT-2024-0420
dfn-cert: DFN-CERT-2024-0388
dfn-cert: DFN-CERT-2024-0343
dfn-cert: DFN-CERT-2024-0306
dfn-cert: DFN-CERT-2024-0299
dfn-cert: DFN-CERT-2024-0285
dfn-cert: DFN-CERT-2024-0267
dfn-cert: DFN-CERT-2024-0251
dfn-cert: DFN-CERT-2024-0215
dfn-cert: DFN-CERT-2024-0211
dfn-cert: DFN-CERT-2024-0164
dfn-cert: DFN-CERT-2024-0154
dfn-cert: DFN-CERT-2024-0101
dfn-cert: DFN-CERT-2024-0092
dfn-cert: DFN-CERT-2024-0088
dfn-cert: DFN-CERT-2024-0067
dfn-cert: DFN-CERT-2024-0063
dfn-cert: DFN-CERT-2024-0062
dfn-cert: DFN-CERT-2024-0024
dfn-cert: DFN-CERT-2024-0022
dfn-cert: DFN-CERT-2024-0013
dfn-cert: DFN-CERT-2023-3219
dfn-cert: DFN-CERT-2023-3218
dfn-cert: DFN-CERT-2023-3210
dfn-cert: DFN-CERT-2023-3201
dfn-cert: DFN-CERT-2023-3200
dfn-cert: DFN-CERT-2023-3195
dfn-cert: DFN-CERT-2023-3193
dfn-cert: DFN-CERT-2023-3191
dfn-cert: DFN-CERT-2023-3185
dfn-cert: DFN-CERT-2023-3184
dfn-cert: DFN-CERT-2023-3183
dfn-cert: DFN-CERT-2023-3182
dfn-cert: DFN-CERT-2023-3175
```

Medium (CVSS: 5.9)
NVT: OpenBSD OpenSSH Information Disclosure Vulnerability (CVE-2020-14145)

Product detection result

```
cpe:/a:openbsd:openssh:7.5
Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)
```

. . . continues on next page . . .

. . . continued from previous page . . .

Summary
OpenBSD OpenSSH is prone to an information disclosure vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     8.5
Installation
path / port:       22/tcp
```

Solution:
Solution type: VendorFix
Update to version 8.5 or later.

Affected Software/OS
OpenBSD OpenSSH versions 5.7 through 8.4.

Vulnerability Insight
The client side in OpenSSH has an Observable Discrepancy leading to an information leak in the algorithm negotiation. This allows man-in-the-middle attackers to target initial connection attempts (where no host key for the server has been cached by the client).

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenBSD OpenSSH Information Disclosure Vulnerability (CVE-2020-14145)`
OID:1.3.6.1.4.1.25623.1.0.117785
Version used: `2021-11-22T14:03:31Z`

Product Detection Result
Product: `cpe:/a:openbsd:openssh:7.5`
Method: `OpenSSH Detection Consolidation`
OID: 1.3.6.1.4.1.25623.1.0.108577)

References

```
cve: CVE-2020-14145
url: http://www.openwall.com/lists/oss-security/2020/12/02/1
cert-bund: WID-SEC-2024-1591
cert-bund: WID-SEC-2024-1082
cert-bund: WID-SEC-2023-1969
cert-bund: WID-SEC-2023-1599
cert-bund: WID-SEC-2023-0068
cert-bund: CB-K20/0995
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2024-1260
dfn-cert: DFN-CERT-2020-2691
```

Medium (CVSS: 5.9)
NVT: Prefix Truncation Attacks in SSH Specification (Terrapin Attack)

Product detection result

```
cpe:/a:ietf:secure_shell_protocol
Detected by SSH Protocol Algorithms Supported (OID: 1.3.6.1.4.1.25623.1.0.105565
↪)
```

Summary

The remote SSH server is supporting an specific encryption algorithm or MAC. Parts of their SSH specification are vulnerable to a novel prefix truncation attack (a.k.a. Terrapin attack).

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
The remote SSH server supports the following possible affected client-to-server
↪encryption algorithm(s):
chacha20-poly1305@openssh.com
The remote SSH server supports the following possible affected server-to-client
↪encryption algorithm(s):
chacha20-poly1305@openssh.com
```

Solution:

Solution type: VendorFix

- Update OpenSSH to version 9.6 or later
- Update Apache MINA SSHD to version 2.12.0 or later
- For other products please contact the vendor for possible fixes / updates

Mitigation:

- To mitigate this protocol vulnerability, OpenSSH suggested a so-called 'strict kex' which alters the SSH handshake to ensure a Man-in-the-Middle attacker cannot introduce unauthenticated messages as well as convey sequence number manipulation across handshakes. Support for strict key exchange has been added to a variety of SSH implementations, including OpenSSH itself, PuTTY, libssh, and more.

Warning: To take effect, both the client and server must support this countermeasure.

As a stop-gap measure, peers may also (temporarily) disable the affected algorithms and use unaffected alternatives like AES-GCM instead until patches are available.

Affected Software/OS

Systems supporting the following encryption algorithm and/or MACs:

- ChaCha20-Poly1305 (chacha20-poly1305@openssh.com) encryption algorithm
- CBC encryption algorithm and Encrypt-then-MAC (*-etm@openssh.com) MAC

. . . continues on next page . . .

. . . continued from previous page . . .

Vulnerability Insight
Parts of the SSH specification are vulnerable to a novel prefix truncation attack (a.k.a. Terrapin attack), which allows a man-in-the-middle attacker to strip an arbitrary number of messages right after the initial key exchange, breaking SSH extension negotiation (RFC8308) in the process and thus downgrading connection security.

Vulnerability Detection Method
Checks the supported algorithms and MACs of the remote SSH server.
Note: This VT has a low QoD because mitigation is possible / available via software updates.
Details: `Prefix Truncation Attacks in SSH Specification (Terrapin Attack)`
OID:1.3.6.1.4.1.25623.1.0.114238
Version used: `2025-04-23T05:39:47Z`

Product Detection Result
Product: `cpe:/a:ietf:secure_shell_protocol`
Method: `SSH Protocol Algorithms Supported`
OID: 1.3.6.1.4.1.25623.1.0.105565)

References
`cve: CVE-2023-48795`
`cve: CVE-2024-41909`
`url: https://terrapin-attack.com`
`url: https://www.openssh.com/txt/release-9.6`
`url: https://lists.apache.org/thread/vwf1ot8wx1njyy8n19j5j2tcnjnozt3b`
`url: https://github.com/apache/mina-sshd/issues/445`
`url: https://github.com/apache/mina-sshd/pull/449`
`cert-bund: WID-SEC-2025-2359`
`cert-bund: WID-SEC-2025-0810`
`cert-bund: WID-SEC-2025-0168`
`cert-bund: WID-SEC-2025-0144`
`cert-bund: WID-SEC-2025-0139`
`cert-bund: WID-SEC-2024-3377`
`cert-bund: WID-SEC-2024-3320`
`cert-bund: WID-SEC-2024-3221`
`cert-bund: WID-SEC-2024-3198`
`cert-bund: WID-SEC-2024-3195`
`cert-bund: WID-SEC-2024-1913`
`cert-bund: WID-SEC-2024-1781`
`cert-bund: WID-SEC-2024-1701`
`cert-bund: WID-SEC-2024-1656`
`cert-bund: WID-SEC-2024-1655`
`cert-bund: WID-SEC-2024-1643`
`cert-bund: WID-SEC-2024-1642`
`cert-bund: WID-SEC-2024-1639`
`cert-bund: WID-SEC-2024-1637`

. . . continues on next page . . .

. . . continued from previous page . . .

```
cert-bund: WID-SEC-2024-1630
cert-bund: WID-SEC-2024-1474
cert-bund: WID-SEC-2024-1248
cert-bund: WID-SEC-2024-1228
cert-bund: WID-SEC-2024-1186
cert-bund: WID-SEC-2024-1082
cert-bund: WID-SEC-2024-0899
cert-bund: WID-SEC-2024-0892
cert-bund: WID-SEC-2024-0889
cert-bund: WID-SEC-2024-0885
cert-bund: WID-SEC-2024-0874
cert-bund: WID-SEC-2024-0869
cert-bund: WID-SEC-2024-0578
cert-bund: WID-SEC-2024-0564
cert-bund: WID-SEC-2024-0523
cert-bund: WID-SEC-2023-3174
dfn-cert: DFN-CERT-2026-0097
dfn-cert: DFN-CERT-2025-3629
dfn-cert: DFN-CERT-2025-3272
dfn-cert: DFN-CERT-2025-2941
dfn-cert: DFN-CERT-2025-2058
dfn-cert: DFN-CERT-2025-2037
dfn-cert: DFN-CERT-2025-1447
dfn-cert: DFN-CERT-2025-1177
dfn-cert: DFN-CERT-2025-1025
dfn-cert: DFN-CERT-2025-0660
dfn-cert: DFN-CERT-2025-0502
dfn-cert: DFN-CERT-2025-0294
dfn-cert: DFN-CERT-2025-0173
dfn-cert: DFN-CERT-2025-0165
dfn-cert: DFN-CERT-2025-0024
dfn-cert: DFN-CERT-2024-3171
dfn-cert: DFN-CERT-2024-2818
dfn-cert: DFN-CERT-2024-2759
dfn-cert: DFN-CERT-2024-2741
dfn-cert: DFN-CERT-2024-2602
dfn-cert: DFN-CERT-2024-2573
dfn-cert: DFN-CERT-2024-2392
dfn-cert: DFN-CERT-2024-2210
dfn-cert: DFN-CERT-2024-2209
dfn-cert: DFN-CERT-2024-2194
dfn-cert: DFN-CERT-2024-2169
dfn-cert: DFN-CERT-2024-2048
dfn-cert: DFN-CERT-2024-2030
dfn-cert: DFN-CERT-2024-2028
dfn-cert: DFN-CERT-2024-1930
dfn-cert: DFN-CERT-2024-1895
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2024-1869
dfn-cert: DFN-CERT-2024-1868
dfn-cert: DFN-CERT-2024-1865
dfn-cert: DFN-CERT-2024-1862
dfn-cert: DFN-CERT-2024-1854
dfn-cert: DFN-CERT-2024-1846
dfn-cert: DFN-CERT-2024-1817
dfn-cert: DFN-CERT-2024-1715
dfn-cert: DFN-CERT-2024-1698
dfn-cert: DFN-CERT-2024-1688
dfn-cert: DFN-CERT-2024-1655
dfn-cert: DFN-CERT-2024-1600
dfn-cert: DFN-CERT-2024-1443
dfn-cert: DFN-CERT-2024-1442
dfn-cert: DFN-CERT-2024-1413
dfn-cert: DFN-CERT-2024-1382
dfn-cert: DFN-CERT-2024-1380
dfn-cert: DFN-CERT-2024-1373
dfn-cert: DFN-CERT-2024-1260
dfn-cert: DFN-CERT-2024-1259
dfn-cert: DFN-CERT-2024-1108
dfn-cert: DFN-CERT-2024-1061
dfn-cert: DFN-CERT-2024-1029
dfn-cert: DFN-CERT-2024-1003
dfn-cert: DFN-CERT-2024-1000
dfn-cert: DFN-CERT-2024-0896
dfn-cert: DFN-CERT-2024-0779
dfn-cert: DFN-CERT-2024-0762
dfn-cert: DFN-CERT-2024-0744
dfn-cert: DFN-CERT-2024-0698
dfn-cert: DFN-CERT-2024-0633
dfn-cert: DFN-CERT-2024-0619
dfn-cert: DFN-CERT-2024-0618
dfn-cert: DFN-CERT-2024-0616
dfn-cert: DFN-CERT-2024-0597
dfn-cert: DFN-CERT-2024-0545
dfn-cert: DFN-CERT-2024-0526
dfn-cert: DFN-CERT-2024-0491
dfn-cert: DFN-CERT-2024-0451
dfn-cert: DFN-CERT-2024-0440
dfn-cert: DFN-CERT-2024-0420
dfn-cert: DFN-CERT-2024-0388
dfn-cert: DFN-CERT-2024-0343
dfn-cert: DFN-CERT-2024-0306
dfn-cert: DFN-CERT-2024-0299
dfn-cert: DFN-CERT-2024-0285
dfn-cert: DFN-CERT-2024-0267
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2024-0251
dfn-cert: DFN-CERT-2024-0215
dfn-cert: DFN-CERT-2024-0211
dfn-cert: DFN-CERT-2024-0164
dfn-cert: DFN-CERT-2024-0154
dfn-cert: DFN-CERT-2024-0101
dfn-cert: DFN-CERT-2024-0092
dfn-cert: DFN-CERT-2024-0088
dfn-cert: DFN-CERT-2024-0067
dfn-cert: DFN-CERT-2024-0063
dfn-cert: DFN-CERT-2024-0062
dfn-cert: DFN-CERT-2024-0024
dfn-cert: DFN-CERT-2024-0013
dfn-cert: DFN-CERT-2023-3219
dfn-cert: DFN-CERT-2023-3218
dfn-cert: DFN-CERT-2023-3210
dfn-cert: DFN-CERT-2023-3201
dfn-cert: DFN-CERT-2023-3200
dfn-cert: DFN-CERT-2023-3195
dfn-cert: DFN-CERT-2023-3193
dfn-cert: DFN-CERT-2023-3191
dfn-cert: DFN-CERT-2023-3185
dfn-cert: DFN-CERT-2023-3184
dfn-cert: DFN-CERT-2023-3183
dfn-cert: DFN-CERT-2023-3182
dfn-cert: DFN-CERT-2023-3175
```

Medium (CVSS: 5.3)
NVT: OpenSSH < 7.8 User Enumeration Vulnerability - Linux

Product detection result

```
cpe:/a:openbsd:openssh:7.5
Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)
```

Summary

OpenSSH is prone to a user enumeration vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     7.8
Installation
path / port:       22/tcp
```

. . . continues on next page . . .

. . . continued from previous page . . .

Impact
Successfully exploitation will allow remote attacker to test whether a certain user exists or not (username enumeration) on a target OpenSSH server.

Solution:
Solution type: VendorFix
Update to version 7.8 or later.

Affected Software/OS
OpenSSH versions 7.7 and prior.

Vulnerability Insight
The flaw is due to not delaying bailout for an invalid authenticating user until after the packet containing the request has been fully parsed, related to auth2-gss.c, auth2-hostbased.c, and auth2-pubkey.c

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenSSH < 7.8 User Enumeration Vulnerability - Linux`
OID:1.3.6.1.4.1.25623.1.0.813864
Version used: `2024-12-13T05:05:32Z`

Product Detection Result
Product: `cpe:/a:openbsd:openssh:7.5`
Method: `OpenSSH Detection Consolidation`
OID: 1.3.6.1.4.1.25623.1.0.108577)

References
```
cve: CVE-2018-15473
url: https://0day.city/cve-2018-15473.html
url: https://github.com/openbsd/src/commit/779974d35b4859c07bc3cb8a12c74b43b0a7d
↪1e0
cert-bund: WID-SEC-2024-1082
cert-bund: CB-K20/0041
cert-bund: CB-K18/1031
cert-bund: CB-K18/0873
dfn-cert: DFN-CERT-2024-1260
dfn-cert: DFN-CERT-2021-2178
dfn-cert: DFN-CERT-2020-2189
dfn-cert: DFN-CERT-2020-0228
dfn-cert: DFN-CERT-2019-2046
dfn-cert: DFN-CERT-2019-0857
dfn-cert: DFN-CERT-2019-0362
dfn-cert: DFN-CERT-2018-2293
dfn-cert: DFN-CERT-2018-2259
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
dfn-cert: DFN-CERT-2018-2191
dfn-cert: DFN-CERT-2018-1806
dfn-cert: DFN-CERT-2018-1696
```

Medium (CVSS: 5.3)
NVT: OpenSSH < 7.6 'sftp-server' Security Bypass Vulnerability - Linux

Product detection result
`cpe:/a:openbsd:openssh:7.5`
`Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)`

Summary
OpenSSH is prone to a security bypass vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     7.6
Installation
path / port:       22/tcp
```

Impact
Successfully exploiting this issue allows local users to bypass certain security restrictions and perform unauthorized actions. This may lead to further attacks.

Solution:
Solution type: VendorFix
Update to version 7.6 or later.

Affected Software/OS
OpenSSH versions prior to 7.6 on Linux.

Vulnerability Insight
The flaw exists in the 'process_open' function in sftp-server.c script which does not properly prevent write operations in readonly mode.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenSSH < 7.6 'sftp-server' Security Bypass Vulnerability - Linux`
OID:1.3.6.1.4.1.25623.1.0.812051
Version used: `2024-12-13T05:05:32Z`

Product Detection Result

. . . continues on next page . . .

. . . continued from previous page . . .

Product: cpe:/a:openbsd:openssh:7.5
Method: OpenSSH Detection Consolidation
OID: 1.3.6.1.4.1.25623.1.0.108577)

References

```
cve: CVE-2017-15906
url: https://www.openssh.com/txt/release-7.6
url: http://www.securityfocus.com/bid/101552
url: https://github.com/openbsd/src/commit/a6981567e8e
cert-bund: WID-SEC-2024-1082
cert-bund: CB-K20/0041
cert-bund: CB-K18/0137
cert-bund: CB-K17/2126
cert-bund: CB-K17/2014
cert-bund: CB-K17/2002
dfn-cert: DFN-CERT-2024-1260
dfn-cert: DFN-CERT-2019-0362
dfn-cert: DFN-CERT-2018-2554
dfn-cert: DFN-CERT-2018-2191
dfn-cert: DFN-CERT-2018-2068
dfn-cert: DFN-CERT-2018-1828
dfn-cert: DFN-CERT-2018-1568
dfn-cert: DFN-CERT-2018-0150
dfn-cert: DFN-CERT-2017-2217
dfn-cert: DFN-CERT-2017-2100
dfn-cert: DFN-CERT-2017-2093
```

Medium (CVSS: 5.3)
NVT: OpenSSH 'auth2-gss.c' User Enumeration Vulnerability - Linux

Product detection result

```
cpe:/a:openbsd:openssh:7.5
Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)
```

Summary

OpenSSH is prone to a user enumeration vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     None
Installation
path / port:       22/tcp
```

. . . continues on next page . . .

. . . continued from previous page . . .

Impact
Successfully exploitation will allow a remote attacker to harvest valid user accounts, which may aid in brute-force attacks.

Solution:
Solution type: WillNotFix
No known solution was made available for at least one year since the disclosure of this vulnerability. Likely none will be provided anymore. General solution options are to upgrade to a newer release, disable respective features, remove the product or replace the product by another one.

Affected Software/OS
OpenSSH version 5.9 through 7.8.

Vulnerability Insight
The flaw exists in the 'auth-gss2.c' source code file of the affected software and is due to insufficient validation of an authentication request packet when the Guide Star Server II (GSS2) component is used on an affected system.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenSSH 'auth2-gss.c' User Enumeration Vulnerability - Linux`
OID:1.3.6.1.4.1.25623.1.0.813888
Version used: `2021-05-28T07:06:21Z`

Product Detection Result
Product: `cpe:/a:openbsd:openssh:7.5`
Method: `OpenSSH Detection Consolidation`
OID: 1.3.6.1.4.1.25623.1.0.108577)

References
`cve: CVE-2018-15919`
`url: https://bugzilla.novell.com/show_bug.cgi?id=1106163`
`url: https://seclists.org/oss-sec/2018/q3/180`
`cert-bund: WID-SEC-2024-1082`
`cert-bund: CB-K18/0885`
`dfn-cert: DFN-CERT-2024-1260`
`dfn-cert: DFN-CERT-2018-2293`
`dfn-cert: DFN-CERT-2018-2191`

Medium (CVSS: 5.3)
NVT: OpenSSH Information Disclosure Vulnerability (CVE-2016-20012)

Product detection result

. . . continues on next page . . .

. . . continued from previous page . . .

cpe:/a:openbsd:openssh:7.5
Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)

Summary
OpenBSD OpenSSH is prone to an information disclosure vulnerability.

Quality of Detection (QoD): 50%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     None
Installation
path / port:       22/tcp
```

Solution:
Solution type: WillNotFix
No known solution was made available for at least one year since the disclosure of this vulnerability. Likely none will be provided anymore. General solution options are to upgrade to a newer release, disable respective features, remove the product or replace the product by another one.

Affected Software/OS
All currently OpenSSH versions are known to be affected.

Vulnerability Insight
OpenSSH allows remote attackers, who have a suspicion that a certain combination of username and public key is known to an SSH server, to test whether this suspicion is correct. This occurs because a challenge is sent only when that combination could be valid for a login session.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: OpenSSH Information Disclosure Vulnerability (CVE-2016-20012)
OID:1.3.6.1.4.1.25623.1.0.117777
Version used: 2022-11-24T10:18:54Z

Product Detection Result
Product: cpe:/a:openbsd:openssh:7.5
Method: OpenSSH Detection Consolidation
OID: 1.3.6.1.4.1.25623.1.0.108577)

References
cve: CVE-2016-20012
url: https://github.com/openssh/openssh-portable/pull/270
url: https://rushter.com/blog/public-ssh-keys/
url: https://utcc.utoronto.ca/~cks/space/blog/tech/SSHKeysAreInfoLeak

. . . continues on next page . . .

. . . continued from previous page . . .

```
cert-bund: WID-SEC-2024-1082
cert-bund: WID-SEC-2024-0229
cert-bund: CB-K21/0979
dfn-cert: DFN-CERT-2024-1260
```

Medium (CVSS: 5.0)
NVT: OpenBSD OpenSSH < 9.2 Unspecified Vulnerability

Product detection result

```
cpe:/a:openbsd:openssh:7.5
Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)
```

Summary

OpenBSD OpenSSH is prone to an unspecified vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     9.2
Installation
path / port:       22/tcp
```

Solution:

Solution type: VendorFix

Update to version 9.2 or later.

Affected Software/OS

OpenBSD OpenSSH prior to version 9.2.

Vulnerability Insight

If the CanonicalizeHostname and CanonicalizePermittedCNAMEs options were enabled, and the system/libc resolver did not check that names in DNS responses were valid, then use of these options could allow an attacker with control of DNS to include invalid characters (possibly including wildcards) in names added to known_hosts files when they were updated. These names would still have to match the CanonicalizePermittedCNAMEs allow-list, so practical exploitation appears unlikely.

Vulnerability Detection Method

Checks if a vulnerable version is present on the target host.

Details: `OpenBSD OpenSSH < 9.2 Unspecified Vulnerability`

OID:1.3.6.1.4.1.25623.1.0.104512

Version used: `2025-01-21T05:37:33Z`

. . . continues on next page . . .

. . . continued from previous page . . .

Product Detection Result
Product: cpe:/a:openbsd:openssh:7.5
Method: OpenSSH Detection Consolidation
OID: 1.3.6.1.4.1.25623.1.0.108577)

References
url: https://www.openssh.com/releasenotes.html#9.2
url: https://www.openwall.com/lists/oss-security/2023/02/02/3

Medium (CVSS: 5.0)
NVT: OpenBSD OpenSSH < 9.3 Unspecified Vulnerability

Product detection result
cpe:/a:openbsd:openssh:7.5
Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)

Summary
OpenBSD OpenSSH is prone to an unspecified vulnerability.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
Installed version: 7.5
Fixed version: 9.3
Installation
path / port: 22/tcp

Solution:
Solution type: VendorFix
Update to version 9.3 or later.

Affected Software/OS
OpenBSD OpenSSH prior to version 9.3.

Vulnerability Insight
ssh(1): Portable OpenSSH provides an implementation of the getrrsetbyname(3) function if the standard library does not provide it, for use by the VerifyHostKeyDNS feature. A specifically crafted DNS response could cause this function to perform an out-of-bounds read of adjacent stack data, but this condition does not appear to be exploitable beyond denial-of-service to the ssh(1) client.

. . . continues on next page . . .

. . . continued from previous page . . .

The getrrsetbyname(3) replacement is only included if the system's standard library lacks this function and portable OpenSSH was not compiled with the ldns library (–with-ldns). getrrsetbyname(3) is only invoked if using VerifyHostKeyDNS to fetch SSHFP records.This problem was found by the Coverity static analyzer.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenBSD OpenSSH < 9.3 Unspecified Vulnerability`
OID:1.3.6.1.4.1.25623.1.0.104635
Version used: `2025-01-21T05:37:33Z`

Product Detection Result
Product: `cpe:/a:openbsd:openssh:7.5`
Method: `OpenSSH Detection Consolidation`
OID: 1.3.6.1.4.1.25623.1.0.108577)

References
`url: https://www.openssh.com/releasenotes.html#9.3`
`url: https://www.openwall.com/lists/oss-security/2023/03/15/8`

Medium (CVSS: 4.0)
NVT: OpenBSD OpenSSH < 9.1 Multiple Vulnerabilities

Product detection result
`cpe:/a:openbsd:openssh:7.5`
`Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)`

Summary
OpenBSD OpenSSH is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
```
Installed version: 7.5
Fixed version:     9.1
Installation
path / port:       22/tcp
```

Solution:
Solution type: VendorFix
Update to version 9.1 or later.

Affected Software/OS

. . . continues on next page . . .

. . . continued from previous page . . .

OpenBSD OpenSSH prior to version 9.1.

Vulnerability Insight
The following vulnerabilities exist:
- A one-byte overflow in SSH- banner processing in ssh-keyscan.
- A double free() in error path of file hashing step in signing/verify code in ssh-keygen.
- A double-free in error path in ssh-keysign.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenBSD OpenSSH < 9.1 Multiple Vulnerabilities`
OID:1.3.6.1.4.1.25623.1.0.127244
Version used: `2025-01-21T05:37:33Z`

Product Detection Result
Product: `cpe:/a:openbsd:openssh:7.5`
Method: `OpenSSH Detection Consolidation`
OID: 1.3.6.1.4.1.25623.1.0.108577)

References
`url: https://www.openssh.com/releasenotes.html#9.1`

[return to 172.31.1.57]

2.1.6 Low general/tcp

Low (CVSS: 2.6)
NVT: TCP Timestamps Information Disclosure

Summary
The remote host implements TCP timestamps and therefore allows to compute the uptime.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
```
It was detected that the host implements RFC1323/RFC7323.
The following timestamps were retrieved with a delay of 1 seconds in-between:
Packet 1: 3413748963
Packet 2: 3413750074
```

Impact
A side effect of this feature is that the uptime of the remote host can sometimes be computed.

Solution:

. . . continues on next page . . .

. . . continued from previous page . . .

Solution type: Mitigation
To disable TCP timestamps on linux add the line 'net.ipv4.tcp_timestamps = 0' to /etc/sysctl.conf. Execute 'sysctl -p' to apply the settings at runtime.
To disable TCP timestamps on Windows execute 'netsh int tcp set global timestamps=disabled' Starting with Windows Server 2008 and Vista, the timestamp can not be completely disabled.
The default behavior of the TCP/IP stack on this Systems is to not use the Timestamp options when initiating TCP connections, but use them if the TCP peer that is initiating communication includes them in their synchronize (SYN) segment.
See the references for more information.

Affected Software/OS
TCP implementations that implement RFC1323/RFC7323.

Vulnerability Insight
The remote host implements TCP timestamps, as defined by RFC1323/RFC7323.

Vulnerability Detection Method
Special IP packets are forged and sent with a little delay in between to the target IP. The responses are searched for a timestamps. If found, the timestamps are reported.
Details: `TCP Timestamps Information Disclosure`
OID:1.3.6.1.4.1.25623.1.0.80091
Version used: `2023-12-15T16:10:08Z`

References
`url: https://datatracker.ietf.org/doc/html/rfc1323`
`url: https://datatracker.ietf.org/doc/html/rfc7323`
`url: https://web.archive.org/web/20151213072445/http://www.microsoft.com/en-us/d`
`↪ownload/details.aspx?id=9152`
`url: https://www.fortiguard.com/psirt/FG-IR-16-090`

[return to 172.31.1.57]

2.1.7 Low general/icmp

Low (CVSS: 2.1)
NVT: ICMP Timestamp Reply Information Disclosure

Summary
The remote host responded to an ICMP timestamp request.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
```
The following response / ICMP packet has been received:
- ICMP Type: 14
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
- ICMP Code: 0
```

Impact
This information could theoretically be used to exploit weak time-based random number generators in other services.

Solution:
Solution type: Mitigation
Various mitigations are possible:
- Disable the support for ICMP timestamp on the remote host completely
- Protect the remote host by a firewall, and block ICMP packets passing through the firewall in either direction (either completely or only for untrusted networks)

Vulnerability Insight
The Timestamp Reply is an ICMP message which replies to a Timestamp message. It consists of the originating timestamp sent by the sender of the Timestamp as well as a receive timestamp and a transmit timestamp.

Vulnerability Detection Method
Sends an ICMP Timestamp (Type 13) request and checks if a Timestamp Reply (Type 14) is received.
Details: `ICMP Timestamp Reply Information Disclosure`
OID:1.3.6.1.4.1.25623.1.0.103190
Version used: `2025-01-21T05:37:33Z`

References
`cve: CVE-1999-0524`
`url: https://datatracker.ietf.org/doc/html/rfc792`
`url: https://datatracker.ietf.org/doc/html/rfc2780`
`cert-bund: CB-K15/1514`
`cert-bund: CB-K14/0632`
`dfn-cert: DFN-CERT-2014-0658`

[return to 172.31.1.57]

2.1.8 Low 22/tcp

Low (CVSS: 3.8)
NVT: OpenBSD OpenSSH 7.4 - 9.9 Unspecified Vulnerability

Product detection result
`cpe:/a:openbsd:openssh:7.5`
`Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)`

. . . continues on next page . . .

. . . continued from previous page . . .

Summary
OpenBSD OpenSSH is prone to an unspecified vulnerability due to a logic error.

Quality of Detection (QoD): 30%

Vulnerability Detection Result

```
Installed version: 7.5
Fixed version:     10.0
Installation
path / port:       22/tcp
```

Solution:
Solution type: VendorFix
Update to version 10.0 or later.

Affected Software/OS
OpenBSD OpenSSH versions 7.4 through 9.9.

Vulnerability Insight
A logic error in sshd(8) caused the DisableForwarding option to not disable X11 or agent forwarding as documented. Note that X11 forwarding is disabled by default in sshd(8) and agent forwarding is not requested by default by ssh(1).

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.
Details: `OpenBSD OpenSSH 7.4 - 9.9 Unspecified Vulnerability`
OID:1.3.6.1.4.1.25623.1.0.105000
Version used: `2025-05-23T05:40:17Z`

Product Detection Result
Product: `cpe:/a:openbsd:openssh:7.5`
Method: `OpenSSH Detection Consolidation`
OID: 1.3.6.1.4.1.25623.1.0.108577)

References

```
cve: CVE-2025-32728
url: https://www.openssh.com/txt/release-10.0
url: https://www.openssh.com/security.html
url: https://www.openwall.com/lists/oss-security/2025/04/09/1
url: https://bugzilla.redhat.com/show_bug.cgi?id=2358767
cert-bund: WID-SEC-2025-2361
cert-bund: WID-SEC-2025-1439
cert-bund: WID-SEC-2025-0775
dfn-cert: DFN-CERT-2025-1562
```

. . . continues on next page . . .

. . . continued from previous page . . .

dfn-cert: DFN-CERT-2025-0918

Low (CVSS: 2.6)
NVT: Weak MAC Algorithm(s) Supported (SSH)

Product detection result
cpe:/a:ietf:secure_shell_protocol
Detected by SSH Protocol Algorithms Supported (OID: 1.3.6.1.4.1.25623.1.0.105565
↪)

Summary
The remote SSH server is configured to allow / support weak MAC algorithm(s).

Quality of Detection (QoD): 80%

Vulnerability Detection Result
The remote SSH server supports the following weak client-to-server MAC algorithm
↪(s):
umac-64-etm@openssh.com
umac-64@openssh.com
The remote SSH server supports the following weak server-to-client MAC algorithm
↪(s):
umac-64-etm@openssh.com
umac-64@openssh.com

Solution:
Solution type: Mitigation
Disable the reported weak MAC algorithm(s).

Vulnerability Detection Method
Checks the supported MAC algorithms (client-to-server and server-to-client) of the remote SSH server.
Currently weak MAC algorithms are defined as the following:
- MD5 based algorithms
- 96-bit based algorithms
- 64-bit based algorithms
- 'none' algorithm
Details: Weak MAC Algorithm(s) Supported (SSH)
OID:1.3.6.1.4.1.25623.1.0.105610
Version used: 2024-06-14T05:05:48Z

Product Detection Result
Product: cpe:/a:ietf:secure_shell_protocol
Method: SSH Protocol Algorithms Supported

. . . continues on next page . . .

. . . continued from previous page . . .

OID: 1.3.6.1.4.1.25623.1.0.105565)

References
`url: https://www.rfc-editor.org/rfc/rfc6668`
`url: https://www.rfc-editor.org/rfc/rfc4253#section-6.4`

Low (CVSS: 2.4)
NVT: OpenBSD OpenSSH < 10.1 Multiple Vulnerabilities

Product detection result
```
cpe:/a:openbsd:openssh:7.5
Detected by OpenSSH Detection Consolidation (OID: 1.3.6.1.4.1.25623.1.0.108577)
```

Summary
OpenBSD OpenSSH is prone to multiple vulnerabilities.

Quality of Detection (QoD): 30%

Vulnerability Detection Result
```
Installed version: 7.5
Fixed version:     10.1
Installation
path / port:       22/tcp
```

Solution:
Solution type: VendorFix
Update to version 10.1 or later.

Affected Software/OS
OpenBSD OpenSSH versions prior to 10.1.

Vulnerability Insight
The following flaws exist:
- CVE-2025-61984: 'ssh' allows control characters in usernames that originate from certain possibly untrusted sources, potentially leading to code execution when a ProxyCommand is used. The untrusted sources are the command line and %-sequence expansion of a configuration file. (A configuration file that provides a complete literal username is not categorized as an untrusted source.)
- CVE-2025-61985: 'ssh' allows the '\0' character in an ssh:// URI, potentially leading to code execution when a ProxyCommand is used.

Vulnerability Detection Method
Checks if a vulnerable version is present on the target host.

. . . continues on next page . . .

. . . continued from previous page . . .

Details: OpenBSD OpenSSH < 10.1 Multiple Vulnerabilities
OID:1.3.6.1.4.1.25623.1.0.119134
Version used: 2025-10-08T05:38:55Z

Product Detection Result
Product: cpe:/a:openbsd:openssh:7.5
Method: OpenSSH Detection Consolidation
OID: 1.3.6.1.4.1.25623.1.0.108577)

References
cve: CVE-2025-61984
cve: CVE-2025-61985
url: https://www.openssh.com/txt/release-10.1
url: https://www.openssh.com/security.html
url: https://www.openwall.com/lists/oss-security/2025/10/06/1
url: https://dgl.cx/2025/10/bash-a-newline-ssh-proxycommand-cve-2025-61984#_
cert-bund: WID-SEC-2025-2212
dfn-cert: DFN-CERT-2026-0218
dfn-cert: DFN-CERT-2025-3384
dfn-cert: DFN-CERT-2025-2768

[return to 172.31.1.57]

2.1.9 Log general/tcp

Log (CVSS: 0.0)
NVT: jQuery Detection Consolidation

Summary
Consolidation of jQuery detections.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
Detected jQuery
Version: 1.11.3
Location: /vendor/plugins/jquery/jquery.min.js
CPE: cpe:/a:jquery:jquery:1.11.3
Concluded from version/product identification result:
src="/vendor/plugins/jquery/jquery.min.js
jQuery v1.11.3
Concluded from version/product identification location:
- Identified file: http://gitea14.trabalho_vulnnet:3000/vendor/plugins/jquery/jq
↪uery.min.js

. . . continues on next page . . .

. . . continued from previous page . . .

```
- Referenced at:   http://gitea14.trabalho_vulnnet:3000/install/
```

Solution:

Log Method
Details: `jQuery Detection Consolidation`
OID:1.3.6.1.4.1.25623.1.0.150658
Version used: `2023-07-14T05:06:08Z`

References
`url: https://jquery.com/`

Log (CVSS: 0.0)
NVT: OpenSSH Detection Consolidation

Summary
Consolidation of OpenSSH detections.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
Detected OpenSSH Server
Version:       7.5
Location:      22/tcp
CPE:           cpe:/a:openbsd:openssh:7.5
Concluded from version/product identification result:
SSH-2.0-OpenSSH_7.5
```

Solution:

Log Method
Details: `OpenSSH Detection Consolidation`
OID:1.3.6.1.4.1.25623.1.0.108577
Version used: `2024-12-13T05:05:32Z`

References
`url: https://www.openssh.com/`

Log (CVSS: 0.0)
NVT: Hostname Determination Reporting

Summary
The script reports information on how the hostname of the target was determined.

. . . continues on next page . . .

. . . continued from previous page . . .

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
Hostname determination for IP 172.31.1.57:
Hostname|Source
gitea14.trabalho_vulnnet|Reverse-DNS
```

Solution:

Log Method

Details: `Hostname Determination Reporting`
OID:1.3.6.1.4.1.25623.1.0.108449
Version used: `2022-07-27T10:11:28Z`

Log (CVSS: 0.0)
NVT: IP Forwarding Enabled - Active Check

Summary

Checks if the remote host has IP forwarding enabled.

Quality of Detection (QoD): 70%

Vulnerability Detection Result

```
It was possible to route a TCP packet through the target host and received an an
↪swer which means IP forwarding is enabled.
```

Solution:

Log Method

Sends a crafted Local Link Layer (LLL) frame and checks the response.
Details: `IP Forwarding Enabled - Active Check`
OID:1.3.6.1.4.1.25623.1.0.147205
Version used: `2021-12-03T08:27:06Z`

References

`cve: CVE-1999-0511`

Log (CVSS: 0.0)
NVT: Traceroute

Summary

. . . continues on next page . . .

. . . continued from previous page . . .

Collect information about the network route and network distance between the scanner host and the target host.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
Network route from scanner (172.30.0.2) to target (172.31.1.57):
172.30.0.2
172.31.1.57
Network distance between scanner and target: 2
```

Solution:

Vulnerability Insight

For internal networks, the distances are usually small, often less than 4 hosts between scanner and target. For public targets the distance is greater and might be 10 hosts or more.

Log Method

A combination of the protocols ICMP and TCP is used to determine the route. This method is applicable for IPv4 only and it is also known as 'traceroute'.
Details: `Traceroute`
OID:1.3.6.1.4.1.25623.1.0.51662
Version used: `2022-10-17T11:13:19Z`

Log (CVSS: 0.0)
NVT: OS Detection Consolidation and Reporting

Summary

This script consolidates the OS information detected by several VTs and tries to find the best matching OS.
Furthermore it reports all previously collected information leading to this best matching OS. It also reports possible additional information which might help to improve the OS detection.
If any of this information is wrong or could be improved please consider to report these to the referenced community forum.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
Best matching OS:
OS:           Linux Kernel
CPE:          cpe:/o:linux:kernel
Found by VT:  1.3.6.1.4.1.25623.1.0.102002 (Operating System (OS) Detection (ICM
↪P))
Concluded from ICMP based OS fingerprint
Setting key "Host/runs_unixoide" based on this information
```

. . . continues on next page . . .

. . . continued from previous page . . .

Solution:

Log Method
Details: `OS Detection Consolidation and Reporting`
OID:1.3.6.1.4.1.25623.1.0.105937
Version used: `2026-01-21T05:50:46Z`

References
`url: https://forum.greenbone.net/c/vulnerability-tests/7`

[return to 172.31.1.57]

2.1.10 Log 3000/tcp

Log (CVSS: 0.0)
NVT: Web Application Scanning Consolidation / Info Reporting

Summary
The script consolidates and reports various information for web application (formerly called 'CGI') scanning.
This information is based on the following scripts / settings:
- HTTP-Version Detection (OID: 1.3.6.1.4.1.25623.1.0.100034)
- No 404 check (OID: 1.3.6.1.4.1.25623.1.0.10386)
- Web mirroring / webmirror.nasl (OID: 1.3.6.1.4.1.25623.1.0.10662)
- Directory Scanner / DDI_Directory_Scanner.nasl (OID: 1.3.6.1.4.1.25623.1.0.11032)
- The configured 'cgi_path' within the 'Scanner Preferences' of the scan config in use
- The configured 'Enable CGI scanning', 'Enable generic web application scanning' and 'Add historic /scripts and /cgi-bin to directories for CGI scanning' within the 'Global variable settings' of the scan config in use
If you think any of this information is wrong please report it to the referenced community forum.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
```
The Hostname/IP "gitea14.trabalho_vulnnet" was used to access the remote host.
Generic web application scanning is disabled for this host via the "Enable gener
↪ic web application scanning" option within the "Global variable settings" of t
↪he scan config in use.
Requests to this service are done via HTTP/1.1.
This service seems to be able to host PHP scripts.
This service seems to be able to host ASP scripts.
The User-Agent "Mozilla/5.0 [en] (X11, U; OpenVAS-VT <version replaced>)" was us
↪ed to access the remote host.
Historic /scripts and /cgi-bin are not added to the directories used for web app
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
↪lication scanning. You can enable this again with the "Add historic /scripts a
↪nd /cgi-bin to directories for CGI scanning" option within the "Global variabl
↪e settings" of the scan config in use.
The following directories were used for web application scanning:
http://gitea14.trabalho_vulnnet:3000/
http://gitea14.trabalho_vulnnet:3000/install
While this is not, in and of itself, a bug, you should manually inspect these di
↪rectories to ensure that they are in compliance with company security standard
↪s
The following directories were excluded from web application scanning because th
↪e "Regex pattern to exclude directories from CGI scanning" setting of the VT "
↪Global variable settings" (OID: 1.3.6.1.4.1.25623.1.0.12288) for this scan was
↪: "/(index\.php|image|img|css|js$|js/|javascript|style|theme|icon|jquery|graph
↪ic|grafik|picture|bilder|thumbnail|media/|skins?/)"
http://gitea14.trabalho_vulnnet:3000/css
http://gitea14.trabalho_vulnnet:3000/img
http://gitea14.trabalho_vulnnet:3000/js
http://gitea14.trabalho_vulnnet:3000/vendor/assets/font-awesome/css
http://gitea14.trabalho_vulnnet:3000/vendor/plugins/cssrelpreload
http://gitea14.trabalho_vulnnet:3000/vendor/plugins/jquery
http://gitea14.trabalho_vulnnet:3000/vendor/plugins/jquery.areyousure
http://gitea14.trabalho_vulnnet:3000/vendor/plugins/jquery.datetimepicker
http://gitea14.trabalho_vulnnet:3000/vendor/plugins/jquery.minicolors
The following CGIs were discovered:
Syntax : cginame (arguments [default value])
http://gitea14.trabalho_vulnnet:3000/install (app_name [Gitea: Git with a cup of
↪ tea] http_port [3000] smtp_host [] disable_registration [] enable_captcha []
↪default_allow_create_organization [] db_name [gitea] app_url [http://localhost
↪:3000/] smtp_passwd [] admin_confirm_passwd [] domain [localhost] admin_email
↪[] admin_name [] no_reply_address [noreply.example.org] ssh_port [22] offline_
↪mode [] enable_federated_avatar [] enable_open_id_sign_up [] mail_notify [] db
↪_type [SQLite3] db_passwd [] require_sign_in_view [] run_user [git] admin_pass
↪wd [] lang [zh-CN] db_user [root] smtp_from [] enable_open_id_sign_in [] ssl_m
↪ode [disable] repo_root_path [/data/git/repositories] log_root_path [/data/git
↪ea/log] default_keep_email_private [] db_host [localhost:3306] db_path [/data/
↪gitea/gitea.db] smtp_user [] lfs_root_path [/data/gitea/lfs] register_confirm
↪[] disable_gravatar [] default_enable_timetracking [] )
The following cgi scripts were excluded from web application scanning because of
↪ the "Regex pattern to exclude cgi scripts" setting of the VT "Web mirroring"
↪(OID: 1.3.6.1.4.1.25623.1.0.10662) for this scan was: "\.(js|css)$"
Syntax : cginame (arguments [default value])
http://gitea14.trabalho_vulnnet:3000/css/index.css (v [1bf6e69c18341244d990250bf
↪5aa3ce0] )
http://gitea14.trabalho_vulnnet:3000/js/index.js (v [1bf6e69c18341244d990250bf5a
↪a3ce0] )
```

Solution:

. . . continues on next page . . .

. . . continued from previous page . . .

Log Method
Details: `Web Application Scanning Consolidation / Info Reporting`
OID:1.3.6.1.4.1.25623.1.0.111038
Version used: `2026-01-13T05:47:36Z`

References
`url: https://forum.greenbone.net/c/vulnerability-tests/7`

Log (CVSS: 0.0)
NVT: Services

Summary
This plugin performs service detection.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
`A web server is running on this port`

Solution:

Vulnerability Insight
This plugin attempts to guess which service is running on the remote port(s). For instance, it searches for a web server which could listen on another port than 80 or 443 and makes this information available for other check routines.

Log Method
Details: `Services`
OID:1.3.6.1.4.1.25623.1.0.10330
Version used: `2025-03-05T05:38:53Z`

Log (CVSS: 0.0)
NVT: Allowed HTTP Methods Enumeration

Summary
Enumerates which HTTP methods are allowed.

Quality of Detection (QoD): 70%

Vulnerability Detection Result
```
The following list contains the URLs and corresponding supported HTTP methods.
URL                                    | HTTP Methods
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
---------------------------------------------------
http://gitea14.trabalho_vulnnet:3000/ | GET,HEAD
```

Solution:

Vulnerability Insight
- Basic HTTP methods: GET, HEAD, POST, PUT, DELETE, CONNECT, OPTIONS, TRACE
- Extended HTTP methods: ACL, BASELINE-CONTROL, BIND, CHECKIN, CHECKOUT, COPY, LABEL, LINK, LOCK, MERGE, MKACTIVITY, MKCALENDAR, MKCOL, MKREDIRECTREF, MKWORKSPACE, MOVE, ORDERPATCH, PATCH, PRI, PROPFIND, PROPPATCH, REBIND, REPORT, SEARCH, UNBIND, UNCHECKOUT, UNLINK, UNLOCK, UPDATE, UPDATEREDIRECTREF, VERSION-CONTROL

Log Method
Sends multiple HTTP requests and checks the responses.
Disclaimer:
- This enumeration script is provided 'as is' (means no support is given) and only providing rudimentary information about the possible enabled methods
- This script doesn't guarantee completeness or full reliability
For more reliable determination of the enabled HTTP methods please inspect the configuration of the web server manually and directly on the target host.
Details: `Allowed HTTP Methods Enumeration`
OID:1.3.6.1.4.1.25623.1.0.153974
Version used: `2025-02-28T05:38:49Z`

Log (CVSS: 0.0)
NVT: Response Time / No 404 Error Code Check

Summary
This VT tests if the remote web server does not reply with a 404 error code and checks if it is replying to the scanners requests in a reasonable amount of time.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
```
The host returns a 30x (e.g. 301) error code when a non-existent file is request
↪ed. Some HTTP-related checks have been disabled.
```

Solution:

Vulnerability Insight
This web server might show the following issues:

. . . continues on next page . . .

. . . continued from previous page . . .

- it is [mis]configured in that it does not return '404 Not Found' error codes when a non-existent file is requested, perhaps returning a site map, search page, authentication page or redirect instead.
The Scanner might enabled some counter measures for that, however they might be insufficient. If a great number of security issues are reported for this port, they might not all be accurate.
- it doesn't response in a reasonable amount of time to various HTTP requests sent by this VT. In order to keep the scan total time to a reasonable amount, the remote web server might not be tested. If the remote server should be tested it has to be fixed to have it reply to the scanners requests in a reasonable amount of time.
Alternatively the 'Maximum response time (in seconds)' preference could be raised to a higher value if longer scan times are accepted.

Log Method
Details: `Response Time / No 404 Error Code Check`
OID:1.3.6.1.4.1.25623.1.0.10386
Version used: `2025-04-11T15:45:04Z`

Log (CVSS: 0.0)
NVT: HTTP Security Headers Detection

Summary
All known security headers are being checked on the remote web server.
On completion a report will hand back whether a specific security header has been implemented (including its value and if it is deprecated) or is missing on the target.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
Header Name     | Header Value
------------------------------
X-Frame-Options | SAMEORIGIN
Missing Headers                   | More Information
-------------------------------------------------------------------------------
↪-------------------------------------------------------------------------------
↪-----------------------------------------------
Content-Security-Policy           | https://owasp.org/www-project-secure-headers
↪/#content-security-policy
Cross-Origin-Embedder-Policy      | https://scotthelme.co.uk/coop-and-coep/, Not
↪e: This is an upcoming header
Cross-Origin-Opener-Policy        | https://scotthelme.co.uk/coop-and-coep/, Not
↪e: This is an upcoming header
Cross-Origin-Resource-Policy      | https://scotthelme.co.uk/coop-and-coep/, Not
↪e: This is an upcoming header
Document-Policy                   | https://w3c.github.io/webappsec-feature-poli
↪cy/document-policy#document-policy-http-header
Feature-Policy                    | https://owasp.org/www-project-secure-headers
```

. . . continues on next page . . .

. . . continued from previous page . . .

```
↪/#feature-policy, Note: The Feature Policy header has been renamed to Permissi
↪ons Policy
Permissions-Policy                | https://w3c.github.io/webappsec-feature-poli
↪cy/#permissions-policy-http-header-field
Referrer-Policy                   | https://owasp.org/www-project-secure-headers
↪/#referrer-policy
Sec-Fetch-Dest                    | https://developer.mozilla.org/en-US/docs/Web
↪/HTTP/Headers#fetch_metadata_request_headers, Note: This is a new header suppo
↪rted only in newer browsers like e.g. Firefox 90
Sec-Fetch-Mode                    | https://developer.mozilla.org/en-US/docs/Web
↪/HTTP/Headers#fetch_metadata_request_headers, Note: This is a new header suppo
↪rted only in newer browsers like e.g. Firefox 90
Sec-Fetch-Site                    | https://developer.mozilla.org/en-US/docs/Web
↪/HTTP/Headers#fetch_metadata_request_headers, Note: This is a new header suppo
↪rted only in newer browsers like e.g. Firefox 90
Sec-Fetch-User                    | https://developer.mozilla.org/en-US/docs/Web
↪/HTTP/Headers#fetch_metadata_request_headers, Note: This is a new header suppo
↪rted only in newer browsers like e.g. Firefox 90
X-Content-Type-Options            | https://owasp.org/www-project-secure-headers
↪/#x-content-type-options
X-Permitted-Cross-Domain-Policies | https://owasp.org/www-project-secure-headers
↪/#x-permitted-cross-domain-policies
X-XSS-Protection                  | https://owasp.org/www-project-secure-headers
↪/#x-xss-protection, Note: Most major browsers have dropped / deprecated suppor
↪t for this header in 2020.
```

Solution:

Log Method
Details: HTTP Security Headers Detection
OID:1.3.6.1.4.1.25623.1.0.112081
Version used: 2025-03-21T15:40:43Z

References
url: https://owasp.org/www-project-secure-headers/
url: https://owasp.org/www-project-secure-headers/#div-headers
url: https://securityheaders.com/

[return to 172.31.1.57]

2.1.11 Log 22/tcp

Log (CVSS: 0.0)
NVT: Services

Summary
This plugin performs service detection.

Quality of Detection (QoD): 80%

Vulnerability Detection Result
`An ssh server is running on this port`

Solution:

Vulnerability Insight
This plugin attempts to guess which service is running on the remote port(s). For instance, it searches for a web server which could listen on another port than 80 or 443 and makes this information available for other check routines.

Log Method
Details: `Services`
OID:1.3.6.1.4.1.25623.1.0.10330
Version used: `2025-03-05T05:38:53Z`

Log (CVSS: 0.0)
NVT: SSH Protocol Versions Supported

Summary
Identification of SSH protocol versions supported by the remote SSH Server. Also reads the corresponding fingerprints from the service.

Quality of Detection (QoD): 95%

Vulnerability Detection Result
```
The remote SSH Server supports the following SSH Protocol Versions:
1.99
2.0
SSHv2 Fingerprint(s):
ecdsa-sha2-nistp256: 1b:29:f0:00:d1:89:f0:23:68:70:12:1f:db:f7:f1:c5
ssh-ed25519: 0c:fa:d2:96:7a:9a:cb:8c:19:b1:69:74:e7:b6:c1:98
ssh-rsa: 1f:02:18:b0:07:bb:55:d3:8d:61:1c:dc:54:2f:b4:16
```

Solution:

Log Method
The following versions are tried: 1.33, 1.5, 1.99 and 2.0.

. . . continues on next page . . .

. . . continued from previous page . . .

Details: SSH Protocol Versions Supported
OID:1.3.6.1.4.1.25623.1.0.100259
Version used: 2024-06-17T08:31:37Z

Log (CVSS: 0.0)
NVT: SSH Protocol Algorithms Supported

Summary
This script detects which algorithms are supported by the remote SSH service.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
The following options are supported by the remote SSH service:
kex_algorithms:
curve25519-sha256,curve25519-sha256@libssh.org,ecdh-sha2-nistp256,ecdh-sha2-nist
↪p384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-gr
↪oup16-sha512,diffie-hellman-group18-sha512,diffie-hellman-group14-sha256,diffi
↪e-hellman-group14-sha1
server_host_key_algorithms:
ssh-ed25519,ssh-rsa,rsa-sha2-512,rsa-sha2-256,ecdsa-sha2-nistp256
encryption_algorithms_client_to_server:
chacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openss
↪h.com,aes256-gcm@openssh.com
encryption_algorithms_server_to_client:
chacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openss
↪h.com,aes256-gcm@openssh.com
mac_algorithms_client_to_server:
umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,h
↪mac-sha2-512-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-64@openssh.com,uma
↪c-128@openssh.com,hmac-sha2-256,hmac-sha2-512,hmac-sha1
mac_algorithms_server_to_client:
umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,h
↪mac-sha2-512-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-64@openssh.com,uma
↪c-128@openssh.com,hmac-sha2-256,hmac-sha2-512,hmac-sha1
compression_algorithms_client_to_server:
none,zlib@openssh.com
compression_algorithms_server_to_client:
none,zlib@openssh.com
```

Solution:

Log Method
Details: SSH Protocol Algorithms Supported
OID:1.3.6.1.4.1.25623.1.0.105565

. . . continues on next page . . .

. . . continued from previous page . . .

Version used: 2026-01-21T05:50:46Z

Log (CVSS: 0.0)
NVT: SSH Server type and version

Summary
This detects the SSH Server's type and version by connecting to the server and processing the buffer received.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
Remote SSH server banner: SSH-2.0-OpenSSH_7.5
Remote SSH supported authentication: publickey
Remote SSH text/login banner: (not available)
This is probably (a):
- OpenSSH
Concluded from remote connection attempt with credentials:
Login:    OpenVASVT
Password: OpenVASVT
```

Solution:

Vulnerability Insight
This information gives potential attackers additional information about the system they are attacking. Versions and Types should be omitted where possible.

Log Method
Details: SSH Server type and version
OID:1.3.6.1.4.1.25623.1.0.10267
Version used: 2025-11-13T05:40:19Z

Log (CVSS: 0.0)
NVT: PQC Key Exchange (KEX) Algorithm(s) Missing (SSH)

Product detection result

```
cpe:/a:ietf:secure_shell_protocol
Detected by SSH Protocol Algorithms Supported (OID: 1.3.6.1.4.1.25623.1.0.105565
↪)
```

Summary
The remote SSH server is configured to NOT allow / support at least ONE Post-Quantum Cryptography (PQC) key exchange (KEX) algorithm(s).

. . . continues on next page . . .

. . . continued from previous page . . .

Quality of Detection (QoD): 80%

Vulnerability Detection Result
`The remote SSH server is NOT supporting at least ONE PQC KEX algorithm.`

Impact
The connection may be vulnerable to 'store now, decrypt later' attacks.

Solution:
Solution type: Mitigation
Update the remote SSH server to a version supporting PQC KEX algorithms (e.g. OpenSSH 8.9 or later) and enable relevant PQC KEX algorithms accordingly.
Please see the references/manual of the remote SSH server and/or contact the vendor of it for more support.

Log Method
Checks the (previously collected) supported KEX algorithms of the remote SSH server.
Currently the following PQC KEX algorithms are defined / getting used for this check:
- sntrup761x25519-sha512@openssh.com
- sntrup761x25519-sha512
- mlkem768x25519-sha256
- sntrup4591761x25519-sha512@tinyssh.org
- ecdh-nistp256-kyber-512r3-sha256-d00@openquantumsafe.org
- ecdh-nistp384-kyber-768r3-sha384-d00@openquantumsafe.org
- ecdh-nistp521-kyber-1024r3-sha512-d00@openquantumsafe.org
- x25519-kyber-512r3-sha256-d00@amazon.com
- mlkem1024nistp384-sha384
- mlkem768nistp256-sha256
- curve25519-frodokem1344-sha512@ssh.com
- ecdh-nistp521-kyber1024-sha512@ssh.com

Details: `PQC Key Exchange (KEX) Algorithm(s) Missing (SSH)`
OID:1.3.6.1.4.1.25623.1.0.119214
Version used: `2025-10-31T05:40:56Z`

Product Detection Result
Product: `cpe:/a:ietf:secure_shell_protocol`
Method: `SSH Protocol Algorithms Supported`
OID: 1.3.6.1.4.1.25623.1.0.105565)

References
`url: https://openssh.com/pq.html`
`url: https://quantumcomputingreport.com/openssh-10-0-introduces-default-post-qua`
`↪ntum-key-exchange-algorithm/`
`url: https://www.nist.gov/news-events/news/2024/08/nist-releases-first-3-finaliz`

. . . continues on next page . . .

. . . continued from previous page . . .

```
↪ed-post-quantum-encryption-standards
url: https://csrc.nist.gov/News/2024/postquantum-cryptography-fips-approved
url: https://www.forescout.com/blog/post-quantum-cryptography-the-real-risks-of-
↪not-adopting-it/
```

[return to 172.31.1.57]

2.1.12 Log general/CPE-T

Log (CVSS: 0.0)
NVT: CPE Inventory

Summary
This routine uses information collected by other routines about CPE identities of operating systems, services and applications detected during the scan.
Note: Some CPEs for specific products might show up twice or more in the output. Background: After a product got renamed or a specific vendor was acquired by another one it might happen that a product gets a new CPE within the NVD CPE Dictionary but older entries are kept with the older CPE.

Quality of Detection (QoD): 80%

Vulnerability Detection Result

```
172.31.1.57|cpe:/a:ietf:secure_shell_protocol:2.0
172.31.1.57|cpe:/a:jquery:jquery:1.11.3
172.31.1.57|cpe:/a:openbsd:openssh:7.5
172.31.1.57|cpe:/o:linux:kernel
```

Solution:

Log Method
Details: `CPE Inventory`
OID:1.3.6.1.4.1.25623.1.0.810002
Version used: `2022-07-27T10:11:28Z`

References
`url: https://nvd.nist.gov/products/cpe`

[return to 172.31.1.57]